

Processo: 105895-5/24

Origem: AGENERSA - AG REG ENERGIA SANEAMENTO

Natureza:

Observação: Verificar a adoção de controles e sua aderência às boas práticas de segurança da informação a fim de mitigar os principais riscos e vulnerabilidades às informações das organizações no âmbito da Administração Pública Estadual, por meio de uma auditoria de conformidade com contornos operacionais.

RELATÓRIO DE AUDITORIA GOVERNAMENTAL

DADOS DA FISCALIZAÇÃO

Número da fiscalização: 49/2024

Modalidade: AUDITORIA DE CONFORMIDADE

Forma de autorização: ORDINÁRIA

Ato originário: PROCESSO TCE-RJ nº 303.285-4/2023

Jurisdicionados: AGENERSA, AGERIO, AGETRANSP, ALERJ, CGE, DEGASE, DETRAN, DPGE, FAETEC, FAPERJ, FIA, FS, GSI, INEA, ISP, JUCERJA, MPRJ, PGE, PROCON, PRODERJ, RIOPREVIDENCIA, RJPREV, SEAP, SECC, SEDEC, SEDSODH, SEEDUC, SEFAZ, SEPLAG, SEPOL, SEPM, SES, SETD, TJRJ, TCE-RJ, UERJ

Objetivo da fiscalização: Verificar a adoção de controles e sua aderência às boas práticas de segurança da informação a fim de mitigar os principais riscos e vulnerabilidades às informações das organizações no âmbito da Administração Pública Estadual, por meio de uma auditoria de conformidade com contornos operacionais.

Ofícios de apresentação: AUD/SGE/GAP 2546/24 a 2579/24 todos de 25/06/2024, e AUD/SGE/GAP 3375/24 de 23/10/2024

Período abrangido: janeiro/19 a dezembro/24

Período de execução: 03/06/24 à 06/12/24

Equipe: Augusto César Benvenuto de Almeida, mat. 02/4823
João Paulo de Freitas Ramirez, mat. 02/4820

Supervisão: Bruno Mattos Souza de Souza Melo, mat. 02/4258

AUDITORIA SEGINFO 2024

36
Organizações

1
Controle Estruturante

6
Controles CIS

27
Medidas básicas

Organizações

Foram fiscalizadas organizações de todos os poderes do Estado do Rio de Janeiro:

Poder Executivo, Poder Legislativo, Poder Judiciário, Ministério Público e Defensoria Pública.

Por que a auditoria foi feita?

A fiscalização teve como objetivo verificar se os órgãos e entidades da Administração Pública do Estado do Rio de Janeiro adotam controles e medidas de segurança alinhadas às boas práticas de segurança da informação.

A escolha do tema considerou a atual relevância das medidas de segurança da informação, uma vez que existe franca ampliação na oferta de serviços públicos digitais, podendo propiciar um aumento considerável no número de vulnerabilidades cibernéticas percebidas por atacantes.

Quais os benefícios estimados?

Estima-se que a partir desse trabalho haja um fortalecimento da governança em segurança da informação nas organizações estaduais, pelo suporte às estruturas de segurança da informação das organizações, aprimoramento na gestão de riscos e na adoção de controles e medidas de segurança alinhadas às boas práticas internacionais do tema.

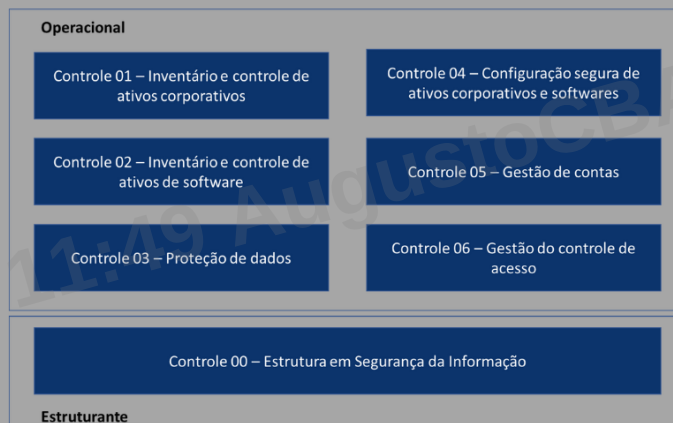
Também se espera que haja a promoção de uma cultura organizacional sustentável que induza comportamentos positivos nos indivíduos em relação à proteção de dados e informações corporativas.

O que o TCE-RJ encontrou?

Os auditores constataram um cenário inicial de maturidade das organizações estaduais do Rio de Janeiro aos controles selecionados de segurança da informação e segurança cibernética.

Ao longo do trabalho, foram identificados cinco achados de auditoria que apontam para um cenário de estruturas de segurança da informação inadequadas e uma adoção insuficiente das medidas básicas de segurança cibernética. Com base nesses achados, foram propostos encaminhamentos com determinações e recomendações para que os órgãos jurisdicionados aprimorem seus controles de segurança da informação.

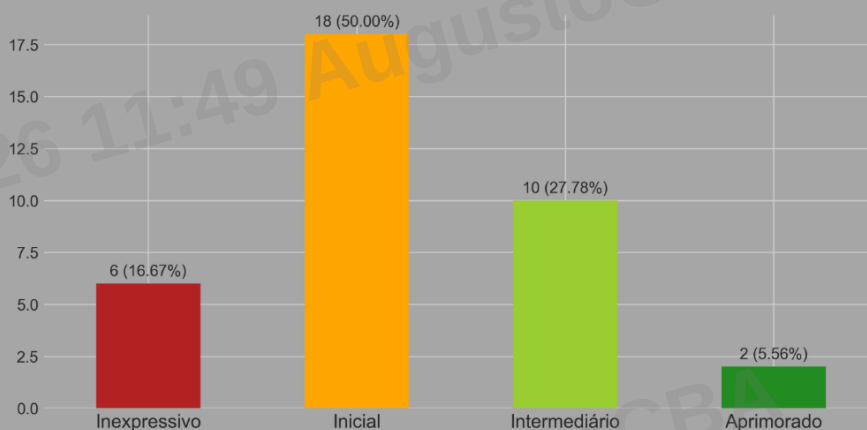
Dimensões e controles avaliados



Índice de Adequação às medidas básicas de SegCiber

Para realizar uma análise quantitativa, foi elaborado o índice de adequação às medidas de segurança cibernética (iSegCiberBase), que varia de 0 a 1 e possui 4 faixas de classificação:

Inexpressivo (até 0,15), Inicial (0,15 a 0,4), Intermediário (0,4 a 0,7) e Aprimorado (acima de 0,7).



SUMÁRIO

SUMÁRIO	3
LISTA DE ANEXOS	4
1. RESUMO	7
2. VISÃO GERAL DO OBJETO	10
2.1. Família ISO 27000	11
2.2. Controles CIS	11
2.3. Base legal	12
3. VISÃO GERAL DA AUDITORIA	13
3.1. Ato de origem	13
3.2. Objetivo e questões de auditoria	13
3.3. Motivação da auditoria	14
3.4. Metodologia utilizada	15
3.5. Limitações	18
3.6. Benefícios estimados	19
3.7. Antecedentes	19
4. RESULTADOS DA AUDITORIA	21
4.1. Análise do índice parcial de adequação às medidas básicas de segurança cibernética das organizações (iSegCiberBase)	21
4.2. Achados da auditoria	23
4.2.1. Achado 1 – Ausência de uma estrutura básica atuante de segurança da informação que estabeleça papéis, políticas e responsabilidades	23
4.2.2. Achado 2 – Medidas básicas de segurança cibernética insuficientes na gestão ativa dos ativos corporativos e softwares	29
4.2.3. Achado 3 – Medidas básicas de segurança cibernética insuficientes na proteção dos dados da organização	36
4.2.4. Achado 4 – Medidas básicas de segurança cibernética insuficientes no estabelecimento de configuração segura dos ativos da organização	45
4.2.5. Achado 5 – Medidas básicas de segurança cibernética insuficientes na gestão de contas e de controle de acesso	52
5. COMENTÁRIOS DO GESTOR	62
5.1. Achado 1 – Ausência de uma estrutura básica atuante de segurança da informação que estabeleça papéis, políticas e responsabilidades	62
5.2. Achado 2 – Medidas básicas de segurança cibernética insuficientes na gestão ativa dos ativos corporativos e softwares	63
5.3. Achado 3 – Medidas básicas de segurança cibernética insuficientes na proteção dos dados da organização	64
5.4. Achado 4 – Medidas básicas de segurança cibernética insuficientes no estabelecimento de configuração segura dos ativos da organização	65
5.5. Achado 5 – Medidas básicas de segurança cibernética insuficientes na gestão de contas e do controle de acesso	65
6. CONSIDERAÇÕES FINAIS	67
7. PROPOSTA DE ENCAMINHAMENTO	68

LISTA DE ANEXOS

ANEXOS	
Documento nº	Descrição
AN01	Ofícios de Apresentação (arquivo digital "AN01 - Ofícios de Apresentação.zip")
AN02	Matriz de Planejamento (arquivo digital "AN02 - Matriz de Planejamento.pdf")
AN03	Questionário iSegCiberBase e metodologia (arquivo digital "AN03 – Questionário iSegCiberBase e informações.zip")
AN04	Evidências (arquivo digital "AN04 – Evidências dos achados.pdf")
AN05	Respostas ao Questionário iSegCiberBase, Comentários do gestor e planilhas de ajustes dos itens (arquivo digital "AN05 – Respostas e ajustes.zip")
AN06	Matriz de Achados (arquivo digital "AN06 – Matriz de Achados.pdf")
AN07	Relatório Público (arquivo digital "AN07 – Relatório Público.pdf")
AN08	Informações da AGENERSA (TSIDs, Respostas e evidências enviadas, Relatório Individual) (arquivo digital "AN08 - AGENERSA.zip")
AN09	Informações da AGERIO (TSIDs, Respostas e evidências enviadas, Relatório Individual) (arquivo digital "AN09 - AGERIO.zip")
AN10	Informações da AGETRANSP (TSIDs, Respostas e evidências enviadas, Relatório Individual) (arquivo digital "AN10 - AGETRANSP.zip")
AN11	Informações da ALERJ (TSIDs, Respostas e evidências enviadas, Relatório Individual) (arquivo digital "AN11 - ALERJ.zip")
AN12	Informações da CGE (TSIDs, Respostas e evidências enviadas, Relatório Individual) (arquivo digital "AN12 - CGE.zip")
AN13	Informações da DEGASE (TSIDs, Respostas e evidências enviadas, Relatório Individual) (arquivo digital "AN13 - DEGASE.zip")
AN14	Informações da DETRAN (TSIDs, Respostas e evidências enviadas, Relatório Individual) (arquivo digital "AN14 - DETRAN.zip")
AN15	Informações da DPGE (TSIDs, Respostas e evidências enviadas, Relatório Individual) (arquivo digital "AN15 - DPGE.zip")
AN16	Informações da FAETEC (TSIDs, Respostas e evidências enviadas, Relatório Individual) (arquivo digital "AN16 - FAETEC.zip")
AN17	Informações da FAPERJ (TSIDs, Respostas e evidências enviadas, Relatório Individual) (arquivo digital "AN17 - FAPERJ.zip")
AN18	Informações da FIA (TSIDs, Respostas e evidências enviadas, Relatório Individual) (arquivo digital "AN18 - FIA.zip")

ANEXOS	
AN19	Informações da FS (TSIDs, Respostas e evidências enviadas, Relatório Individual) (arquivo digital "AN19 - FS.zip")
AN20	Informações da GSI (TSIDs, Respostas e evidências enviadas, Relatório Individual) (arquivo digital "AN20 - GSI.zip")
AN21	Informações da INEA (TSIDs, Respostas e evidências enviadas, Relatório Individual) (arquivo digital "AN21 - INEA.zip")
AN22	Informações da ISP (TSIDs, Respostas e evidências enviadas, Relatório Individual) (arquivo digital "AN22 - ISP.zip")
AN23	Informações da JUCERJA (TSIDs, Respostas e evidências enviadas, Relatório Individual) (arquivo digital "AN23 - JUCERJA.zip")
AN24	Informações da MPRJ (TSIDs, Respostas e evidências enviadas, Relatório Individual) (arquivo digital "AN24 - MPRJ.zip")
AN25	Informações da PGE (TSIDs, Respostas e evidências enviadas, Relatório Individual) (arquivo digital "AN25 - PGE.zip")
AN26	Informações da PROCON (TSIDs, Respostas e evidências enviadas, Relatório Individual) (arquivo digital "AN26 - PROCON.zip")
AN27	Informações da PRODERJ (TSIDs, Respostas e evidências enviadas, Relatório Individual) (arquivo digital "AN27 - PRODERJ.zip")
AN28	Informações da RIOPREVIDENCIA (TSIDs, Respostas e evidências enviadas, Relatório Individual) (arquivo digital "AN28 - RIOPREVIDENCIA.zip")
AN29	Informações da RJPREV (TSIDs, Respostas e evidências enviadas, Relatório Individual) (arquivo digital "AN29 - RJPREV.zip")
AN30	Informações da SEAP (TSIDs, Respostas e evidências enviadas, Relatório Individual) (arquivo digital "AN30 - SEAP.zip")
AN31	Informações da SECC (TSIDs, Respostas e evidências enviadas, Relatório Individual) (arquivo digital "AN31 - SECC.zip")
AN32	Informações da SEDEC (TSIDs, Respostas e evidências enviadas, Relatório Individual) (arquivo digital "AN32 - SEDEC.zip")
AN33	Informações da SEDSODH (TSIDs, Respostas e evidências enviadas, Relatório Individual) (arquivo digital "AN33 - SEDSODH.zip")
AN34	Informações da SEEDUC (TSIDs, Respostas e evidências enviadas, Relatório Individual) (arquivo digital "AN34 - SEEDUC.zip")
AN35	Informações da SEFAZ (TSIDs, Respostas e evidências enviadas, Relatório Individual) (arquivo digital "AN35 - SEFAZ.zip")
AN36	Informações da SEPLAG (TSIDs, Respostas e evidências enviadas, Relatório Individual) (arquivo digital "AN36 - SEPLAG.zip")

ANEXOS	
AN37	Informações da SEPOL (TSIDs, Respostas e evidências enviadas, Relatório Individual) (arquivo digital "AN37 - SEPOL.zip")
AN38	Informações da SEPM (TSIDs, Respostas e evidências enviadas, Relatório Individual) (arquivo digital "AN38 - SEPM.zip")
AN39	Informações da SES (TSIDs, Respostas e evidências enviadas, Relatório Individual) (arquivo digital "AN39 - SES.zip")
AN40	Informações da SETD (TSIDs, Respostas e evidências enviadas, Relatório Individual) (arquivo digital "AN40 - SETD.zip")
AN41	Informações da TCERJ (TSIDs, Respostas e evidências enviadas, Relatório Individual) (arquivo digital "AN41 - TCERJ.zip")
AN42	Informações da TJRJ (TSIDs, Respostas e evidências enviadas, Relatório Individual) (arquivo digital "AN42 - TJRJ.zip")
AN43	Informações da UERJ (TSIDs, Respostas e evidências enviadas, Relatório Individual) (arquivo digital "AN43 - UERJ.zip")

1. RESUMO

Trata-se de relatório de auditoria de conformidade com aspectos operacionais realizada em 36 organizações da Administração Pública do Estado do Rio de Janeiro no período entre 03/06/2024 e 06/12/2024, com o objetivo de verificar a adoção de controles e medidas de segurança alinhadas às boas práticas de segurança da informação pelos órgãos e entidades da Administração Pública do Estado do Rio de Janeiro.

A escolha do tema considerou a atual relevância das medidas de segurança da informação, uma vez que existe franca ampliação na oferta de serviços públicos digitais, podendo propiciar um aumento considerável no número de vulnerabilidades cibernéticas percebidas por atacantes.

A fiscalização foi incluída no Plano Anual de Auditoria Governamental -PAAG de 2024 (aprovado no processo TCE-RJ n.º 303.285-4/23). A partir do objetivo do trabalho, foram selecionados um conjunto de controles fundamentais de segurança da informação e formuladas as seguintes questões de auditoria:

- **Questão 1:** As organizações possuem uma estrutura básica atuante de segurança da informação que estabelece papéis, políticas e responsabilidades?
- **Questão 2:** As organizações adotam as medidas básicas de higiene cibernética para gerenciar ativamente os ativos corporativos conectados à sua infraestrutura e os *softwares* utilizados conforme disposto nos Controles 1 e 2 dos Controles CIS v8?
- **Questão 3:** As organizações adotam as medidas básicas de higiene cibernética para a proteção de seus dados conforme disposto no Controle 3 dos Controles CIS v8?
- **Questão 4:** As organizações adotam as medidas básicas de higiene cibernética para estabelecer e manter a configuração segura de seus ativos e *softwares* conforme disposto no Controle 4 dos Controles CIS v8?
- **Questão 5:** As organizações adotam as medidas básicas de higiene cibernética para atribuir e gerenciar a autorização de credenciais para contas de usuários, bem como para criar, alterar e revogar credenciais e privilégios de acesso dessas contas, conforme disposto nos Controles 5 e 6 dos Controles CIS v8?

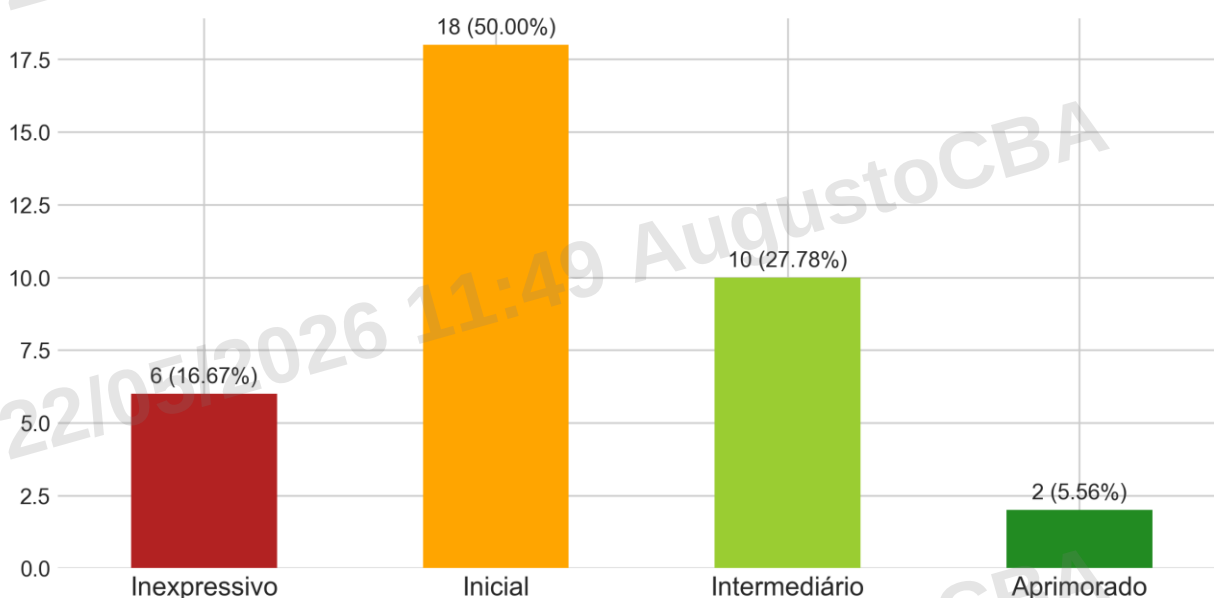
A metodologia adotada na fiscalização foi a autoavaliação de controles internos (do inglês *Control Self-Assessment*), por meio da qual é disponibilizado um questionário eletrônico para que os gestores preencham as respostas que melhor refletem a situação dos órgãos em relação aos controles básicos de segurança da informação.

Após a coleta e análise das respostas, foi realizada a validação e confronto das evidências enviadas com as respostas fornecidas, seguida do cálculo do índice parcial¹ de adequação às medidas básicas de segurança cibernética das organizações (iSegCiberBase). Esse índice abrangeu, inicialmente, o Controle 0, baseado na Norma Técnica ABNT NBR ISO/IEC 27001:2022, e os Controles 1 a 6, amparados nas medidas básicas de segurança cibernética dos Controles CIS versão 8.

Ao término da fase de execução da auditoria foram submetidos relatórios individuais preliminares para cada jurisdicionado, com o objetivo de coletar seus comentários sobre os achados, conclusões e encaminhamentos propostos pela Equipe, encerrando assim o caráter dialógico do trabalho realizado.

O resultado aponta, em linhas gerais, para um cenário inicial de maturidade das organizações às medidas básicas de segurança cibernética, como demonstrado na Figura 1, em que se nota que 24 dos 36 jurisdicionados (66,7%) estão nos níveis de maturidade Inexpressivo ou Inicial.

Figura 1 - Níveis de maturidade das organizações às medidas básicas de segurança cibernética



(Fonte: elaboração própria)

¹ O índice completo será elaborado em fiscalizações futuras, após a conclusão da avaliação de todas as medidas básicas de segurança de higiene cibernética previstas nos Controles CIS

Ao longo do trabalho, foram identificados cinco achados de auditoria que apontam para um cenário de estruturas de segurança da informação inadequadas e uma adoção insuficiente das medidas básicas de segurança cibernética. Com base nesses achados, foram propostos encaminhamentos com determinações e recomendações para que os órgãos jurisdicionados aprimorem seus controles de segurança da informação.

Nesse sentido, foram propostas até 27 medidas por auditado a serem adotadas para melhorias na segurança da informação das organizações.

Entre os benefícios estimados desta fiscalização, destacam-se o fortalecimento da governança em segurança da informação nas organizações estaduais, pelo suporte às estruturas de segurança da informação das organizações, aprimoramento na gestão de riscos e na adoção de controles e medidas de segurança alinhadas às boas práticas internacionais do tema.

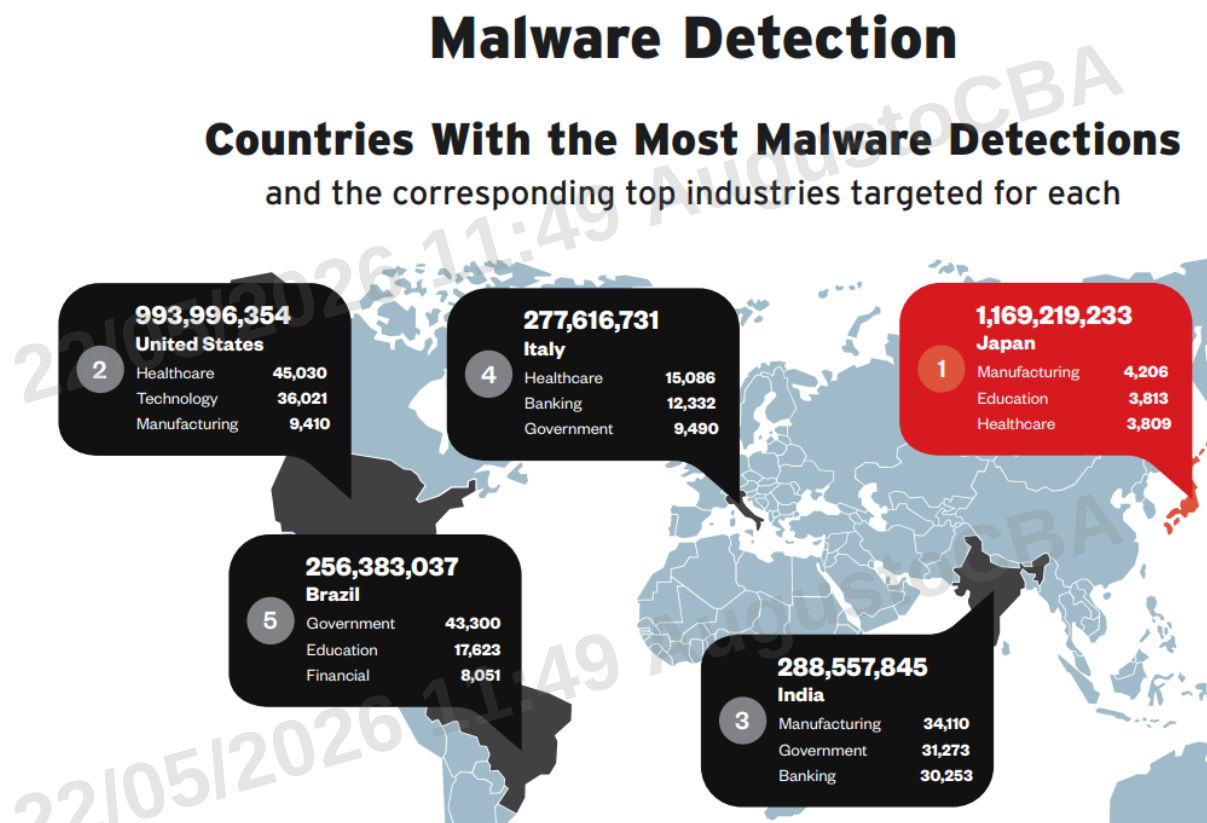
As informações veiculadas neste relatório possuem como usuários, além do Corpo Deliberativo deste TCE-RJ, o Ministério Público de Contas, os dirigentes máximos, as unidades de controle interno e os gestores de segurança da informação e de Tecnologia da Informação das organizações fiscalizadas.

2. VISÃO GERAL DO OBJETO

A crescente integração de tecnologias da informação nos negócios, aliada ao aumento da conectividade, tem impulsionado avanços significativos em diversas áreas da sociedade, incluindo a transição do setor público para um Governo Digital mais eficiente e moderno.

No entanto, esses benefícios trazem consigo desafios igualmente complexos: a evolução constante das ameaças cibernéticas. De acordo com o Relatório Anual de Cibersegurança de 2023 da Trend Micro², o Brasil ocupou a quinta posição global em detecções de *malware* no ano. Destacam-se os dados que apontam o setor público como o mais afetado por essas ameaças, conforme ilustrado na Figura 2.

Figura 2 - Top 5 países em detecção de malware em 2023 (Trend Micro)



(Fonte: Relatório Anual de Cibersegurança de 2023, Trend Micro)

Diante desse cenário, torna-se imprescindível que as organizações públicas incorporem em seu planejamento medidas robustas para mitigar os crescentes riscos à segurança da informação. Essas medidas devem garantir a proteção da

² Disponível em: [Relatório Anual de Cibersegurança de 2023 da Trend Micro](#). Acesso em 07/11/2024.

confidencialidade, integridade e disponibilidade das informações, independentemente do meio em que são armazenadas, processadas ou transmitidas.

Entre as práticas recomendadas para enfrentar esses desafios, destacam-se as normas da família ISO/IEC 27000 e o conjunto de controles críticos de segurança cibernética descritos no *framework* CIS Controls versão 8.

2.1. Família ISO 27000

As normas da família ISO/IEC 27000 fornecem um conjunto de requisitos, regras e diretrizes para se desenvolver, manter e melhorar continuamente um Sistema de Gestão de Segurança da Informação - SGSI.

Dentro dessa família, destacam-se a ISO/IEC 27001, que define os requisitos para um SGSI, além de detalhar como uma organização pode avaliar e tratar riscos de segurança da informação de forma sistemática e baseada em critérios bem definidos, e a ISO/IEC 27002, que fornece um conjunto abrangente de controles e diretrizes a serem implementados pelo SGSI para mitigar os riscos identificados.

2.2. Controles CIS

Os Controles CIS³ são um conjunto prioritário e prescritivo de práticas recomendadas de segurança cibernética, selecionadas por especialistas do Center for Internet Security – CIS⁴, para mitigar os ataques e ameaças de segurança mais frequentes.

Atualmente na versão 8.1, o *framework* consiste em 18 controles organizados em 153 medidas de segurança (*safeguards*) bem definidas. Para simplificar e priorizar a implementação eficaz dessas medidas, o CIS estruturou três Grupos de Implementação (IGs) - IG1, IG2 e IG3. Esses grupos são definidos com base no perfil de risco e nos recursos disponíveis para que cada organização implemente as salvaguardas propostas.

Entre os grupos, o IG1 representa o conjunto de medidas básicas de segurança cibernética que todas as organizações devem adotar para se proteger contra os ataques

³ Controles CIS. Disponível em < <https://learn.cisecurity.org/cis-controls-download>>. Acesso em 18/12/2024.

⁴ O Center for Internet Security - CIS é uma entidade sem fins lucrativos cuja missão é "fazer o mundo conectado um lugar mais seguro desenvolvendo, validando e promovendo tempestivamente melhores soluções práticas que ajudem pessoas, negócios e governos a se protegerem contra ameaças cibernéticas". O CIS lidera uma comunidade global de profissionais de TI que melhoram continuamente essas soluções e proveem produtos e serviços para proteção proativa contra ameaças emergentes. Entre os produtos providos pelo CIS, destacam-se os Controles CIS v8.1.

cibernéticos mais comuns. Conhecido como "higiene cibernética básica", esse nível estabelece um padrão mínimo de segurança da informação.

No contexto dos Controles CIS, o *Community Defense Model* (CDM), estudo elaborado pelo CIS para avaliar seus controles de segurança cibernética, demonstrou que os Controles CIS v8 são capazes de neutralizar 86% das técnicas e padrões de ataque mapeados no *framework* MITRE ATT&CK⁵ e que apenas as medidas de segurança do IG1 conseguem mitigar 74% desses ataques.

2.3. Base legal

A administração pública do Estado do Rio de Janeiro possui normativos específicos em matéria de segurança da informação.

No âmbito do Poder Executivo, além de normas intra-organizacionais, como Portarias e Políticas internas, a segurança da informação é regulamentada pelas Instruções normativas editadas pelo Diretor-Geral do SETIC⁶, atualmente sob a responsabilidade do PRODERJ.

Para regulamentar procedimentos de segurança da informação nos órgãos e entidades do Poder Executivo, o PRODERJ publicou a Instrução Normativa nº 02/2022. Essa norma estabelece, em seu art. 9º, que os procedimentos de segurança devem ser claros, objetivos, regularmente revisados e amplamente divulgados.

No âmbito do Poder Judiciário, foi elaborada a Estratégia de Segurança da Informação e Cibernética (ESIC-PJERJ)⁷, visando aprimorar o nível de maturidade em segurança cibernética. Essa estratégia visa tornar as informações e o espaço cibernético mais confiáveis, resilientes, inclusivos e seguros.

⁵ O framework MITRE ATT&CK, atualmente na versão 8.2, é uma referência mundialmente reconhecida que cataloga táticas e técnicas de ataques cibernéticos. Disponível em: [MITRE ATT&CK](#). Acesso em 07/11/2024

⁶ O Sistema Estadual de Tecnologia da Informação e Comunicação – SETIC, conforme Decreto Estadual nº 48.997/2024, representa o conjunto de recursos humanos, tecnológicos e de equipamentos voltados para o estabelecimento e a implementação de políticas para a informação e a comunicação pública do Estado do Rio de Janeiro.

⁷ Disponível em: [ESIC-PJERJ](#). Acesso em 08/11/2024.

3. VISÃO GERAL DA AUDITORIA

A presente fiscalização foi conduzida em conformidade com o Manual de Auditoria Governamental do TCE-RJ, baseado nas Normas Brasileiras de Auditoria Aplicadas ao Setor Público.

3.1. Ato de origem

Processo TCE-RJ n.º 303.285-4/23, que aprovou o Plano Anual de Auditorias Governamentais (PAAG) para o exercício de 2024.

3.2. Objetivo e questões de auditoria

A presente fiscalização tem por objetivo verificar se os órgãos e entidades da Administração Pública do Estado do Rio de Janeiro adotam controles e medidas de segurança alinhadas às boas práticas de segurança da informação.

Como parte da estratégia para garantir uma implantação eficiente e orientada ao risco, foi dada, neste trabalho, prioridade inicial às medidas básicas de segurança cibernética dos controles de número 1 a 6. Essa seleção foca nos elementos fundamentais da higiene cibernética básica e que todas as organizações devem implementar para estabelecerem um arcabouço robusto de segurança cibernética.

Estes controles selecionados abrangem desde a gestão de inventário de ativos até o controle de acesso, configurando-se como uma base sólida para a proteção contra as ameaças mais prevalentes e severas.

Uma descrição detalhada da implementação destes controles específicos será apresentada nas seções subsequentes, oferecendo uma visão clara de como eles contribuem significativamente para a mitigação de riscos cibernéticos.

Dessa forma, foram formuladas as seguintes questões de auditoria:

- **Questão 1:** As organizações possuem uma estrutura básica atuante de segurança da informação que estabelece papéis, políticas e responsabilidades?
- **Questão 2:** As organizações adotam as medidas básicas de higiene cibernética para gerenciar ativamente os ativos corporativos conectados à sua infraestrutura e os *softwares* utilizados conforme disposto nos Controles 1 e 2 dos Controles CIS v8?

- **Questão 3:** As organizações adotam as medidas básicas de higiene cibernética para a proteção de seus dados conforme disposto no Controle 3 dos Controles CIS v8?
- **Questão 4:** As organizações adotam as medidas básicas de higiene cibernética para estabelecer e manter a configuração segura de seus ativos e *softwares* conforme disposto no Controle 4 dos Controles CIS v8?
- **Questão 5:** As organizações adotam as medidas básicas de higiene cibernética para atribuir e gerenciar a autorização de credenciais para contas de usuários, bem como para criar, alterar e revogar credenciais e privilégios de acesso dessas contas, conforme disposto nos Controles 5 e 6 dos Controles CIS v8?

3.3. Motivação da auditoria

Desde 2022, o governo do Estado do Rio de Janeiro tem direcionado esforços para avançar na temática de Governo Digital e Transformação Digital. Nesse contexto, foi elaborada a Estratégia de Governo Digital, que busca oferecer serviços públicos mais ágeis, menos burocráticos e de maior qualidade aos cidadãos fluminenses.

A ampliação da oferta de serviços públicos digitais, no entanto, pode acarretar um aumento significativo no número de vulnerabilidades exploráveis por atacantes. Isso demanda uma atuação proativa dos Tribunais de Contas para verificar a existência de controles adequados que mitiguem os riscos associados.

Além desse desafio, as organizações públicas enfrentam riscos cibernéticos críticos, como vazamento de dados confidenciais, interrupção de serviços públicos e violações de privacidade dos cidadãos. Esses riscos podem resultar em consequências graves, incluindo perda de informações sensíveis e a erosão da confiança pública nas instituições governamentais.

No primeiro semestre de 2024, esta Coordenadoria realizou um levantamento (Processo TCE-RJ nº 100.749-5/2024) para identificar os sistemas de informação críticos das organizações públicas do Estado do Rio de Janeiro, bem como suas características e riscos associados.

A fiscalização mapeou o perfil dos sistemas de informação governamentais, identificou aqueles mais vulneráveis a ameaças cibernéticas e analisou quais sistemas têm maior potencial de impacto para a sociedade e a Administração. Foram também verificadas as vulnerabilidades que conferem os maiores riscos a esses sistemas.

Diante desse cenário, é fundamental auditar a adoção de medidas eficazes de proteção contra as ameaças cibernéticas em constante evolução, garantindo a segurança e a continuidade da prestação dos serviços na Administração do Estado do Rio de Janeiro.

3.4. Metodologia utilizada

Em consonância com as normas de auditoria no setor público e com o Manual de Auditorias Governamentais do TCE-RJ, o presente trabalho foi dividido em 3 fases: planejamento, execução e relatório.

Na fase de planejamento, foi realizado estudo acerca das melhores práticas e dos normativos existentes e vigentes sobre o tema da fiscalização, bem como dos trabalhos de escopo similar, destacando-se o processo TCU nº 036.301/2021-3⁸.

Com base nesses estudos, a equipe de auditoria desenvolveu um questionário para coletar dados e informações sobre as práticas de segurança da informação adotadas pelas organizações, a fim de responder às questões formuladas na matriz de planejamento.

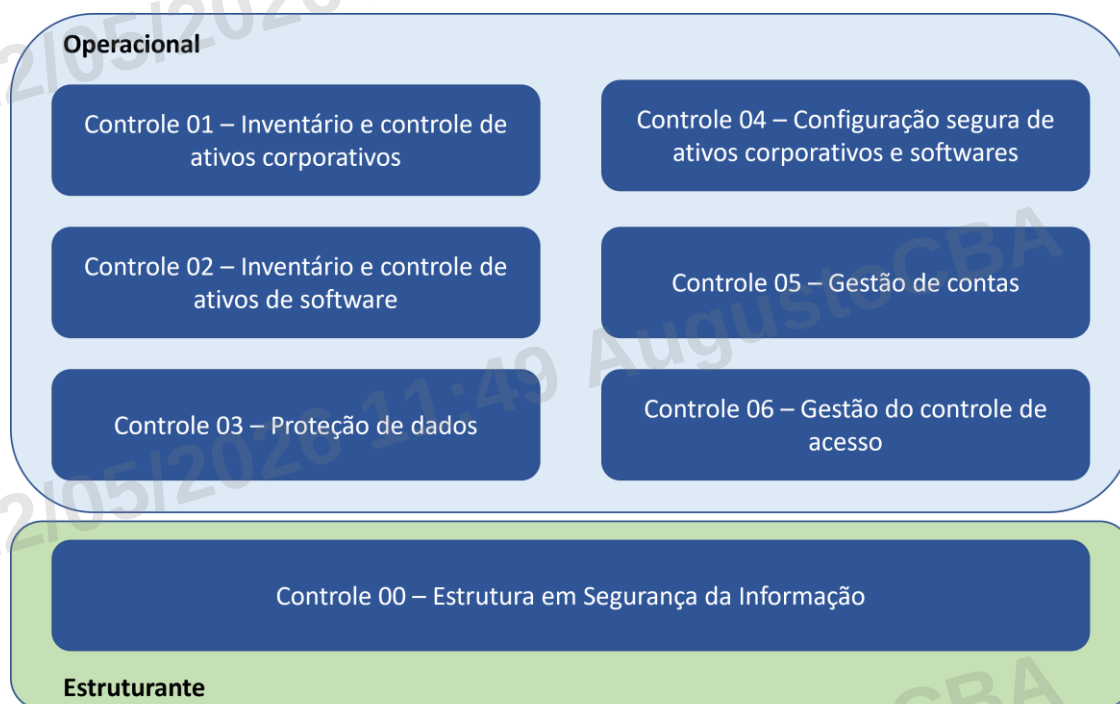
O método utilizado para avaliar as organizações foi o de autoavaliação de controles (do inglês *Control Self-Assessment* – CSA), por meio do qual foi disponibilizado um questionário eletrônico para que os gestores preenchessem as respostas que melhor refletiam a situação das respectivas organizações com relação às medidas de segurança e controles elencados.

Além de permitir que as organizações verificassem quais controles foram implementados, as questões também podem ser utilizadas como referência para a condução de futuras iniciativas de adequação.

O questionário contemplou questões organizadas em duas perspectivas e em 7 controles (Figura 3). As questões tiveram como referência a Norma Técnica ABNT NBR ISO/IEC 27001:2022 (Segurança da informação, segurança cibernética e proteção à privacidade - Sistemas de gestão da segurança da informação - Requisitos) e as medidas básicas de segurança cibernética dos Controles 1 a 6 dos Controles CIS versão 8.

⁸ Auditoria de acompanhamento que teve como objetivo o mapeamento das organizações públicas federais quanto à implementação de controles críticos de segurança cibernética.

Figura 3 - Dimensões e controles avaliados



(Fonte: elaboração própria)

A ferramenta escolhida para enviar as perguntas aos jurisdicionados e coletar suas respostas foi o *LimeSurvey*, um *software* livre que permite a aplicação de questionários *online* com uma gama de funcionalidades, amplamente adotado pelo Tribunal de Contas do Estado do Rio de Janeiro em suas auditorias.

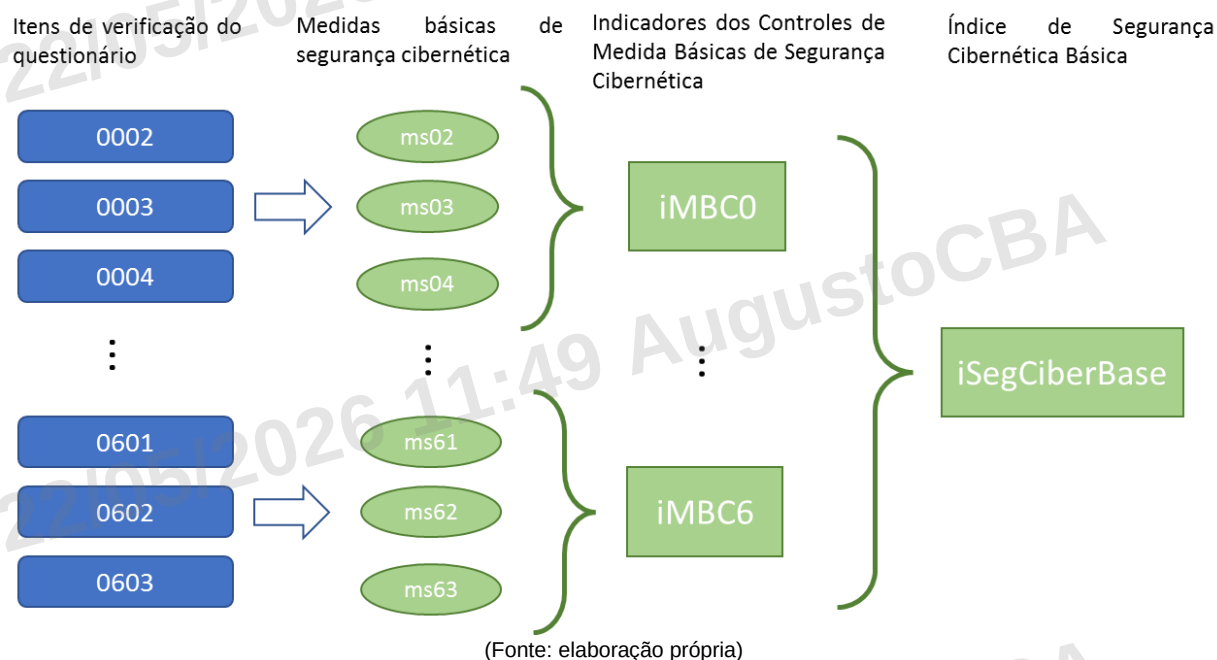
Com o objetivo de consolidar os dados obtidos e viabilizar a comparação entre as organizações auditadas, foram estabelecidos indicadores para cada item do questionário, os quais compõem os subíndices que mensuram os controles de medidas básicas de segurança cibernética (iMBC) de cada controle avaliado. Foram definidos quatro níveis⁹ de capacidade para os subíndices dos controles.

Ao final, calculou-se o índice parcial de adequação às medidas básicas de segurança cibernética das organizações (iSegCiberBase), abrangendo, por enquanto, os controles 00 a 06.

A Figura, a seguir, apresenta como foi estruturada a metodologia do índice.

⁹ Os níveis de capacidade para classificar os controles foram definidos em “Não atingido” (valor menor ou igual a 0,15), “Parcialmente atingido” (valor maior do que 0,15 e menor ou igual a 0,5), “Largamente atingido” (valor maior do que 0,5 e menor ou igual a 0,85) e “Plenamente atingido” (valor maior do que 0,85).

Figura 4 - Composição do índice e dos indicadores



Conforme o valor do índice (iSegCiberBase) obtido, as organizações foram categorizadas em níveis de maturidade¹⁰ quanto à adoção das medidas básicas de segurança cibernética. A fórmula de cálculo do iSegCiberBase está disponível no Anexo AN03.

O índice completo será elaborado em fiscalizações futuras, após a conclusão da avaliação de todas as medidas básicas de segurança de higiene cibernética previstas nos Controles CIS.

Cumpre destacar que todos os 36 jurisdicionados auditados responderam e submeteram o questionário tempestivamente. Assim, todas as respostas e documentos enviados pelas organizações foram analisados pela equipe de auditoria. As evidências encaminhadas que não atenderam aos critérios pré-estabelecidos para avaliação dos documentos ensejaram a alteração das respostas (AN05).

Ao final da fase de execução, buscando fortalecer o caráter dialógico da fiscalização, permitindo o esclarecimento de pontos obscuros, a correção de informações imprecisas ou inconsistentes, e o aperfeiçoamento das medidas propostas, foi

¹⁰ Os níveis de maturidade para classificar as organizações foram definidos em "Inexpressivo" (valor menor ou igual a 0,15), "Inicial" (valor maior do que 0,15 e menor ou igual a 0,4), "Intermediário" (valor maior do que 0,4 e menor ou igual a 0,7) e "Aprimorado" (indicador maior do que 0,7).

encaminhado um relatório individual preliminar¹¹ para cada jurisdicionado contendo os achados da auditoria, com suas situações encontradas específicas e as propostas de encaminhamento sugeridas pela Equipe, bem como as respostas ajustadas em função da análise documental, permitindo que as organizações apresentassem suas considerações sobre os apontamentos.

Assim, os comentários remetidos pelos gestores foram avaliados para consolidação do resultado da fiscalização.

Na fase de elaboração do relatório, a Equipe de Auditoria produziu o presente relatório sigiloso, bem como 35 relatórios individuais (todas as 36 organizações, exceto a RJPREV¹²) contemplando uma visão geral das medidas básicas de segurança cibernética da organização, os achados, as situações encontradas, as propostas de encaminhamento e um plano de ação específico para cada entidade.

Em prol da transparência e promoção do controle social, a Equipe também elaborou um Relatório Público (AN07), destinado a demonstrar o trabalho realizado e apresentar o cenário geral de segurança da informação mensurado.

3.5. Limitações

A principal limitação desta auditoria deriva do uso de questionário autodeclaratório, o que pode gerar inconsistências nas respostas fornecidas pelos gestores.

Para mitigar essa limitação, foram solicitadas evidências documentais relacionadas às seis práticas de segurança da informação consideradas mais fundamentais: estrutura de segurança da informação (SI), política de segurança da informação (PSI), inventário de ativos, inventário de softwares, inventário de dados e o processo de gestão de dados. Essas evidências foram utilizadas para corroborar as informações apresentadas pelos gestores.

Ressalta-se que tal limitação não impediu o pleno atingimento do objetivo proposto neste trabalho.

¹¹ Os relatórios preliminares individuais enviados aos jurisdicionados encontram-se presentes no TSID03 de cada anexo das organizações auditadas (AN08 a AN43).

¹² Uma vez que a RJPREV está alocada dentro da infraestrutura da SEFAZ, conforme informado na etapa de coleta de informações, as medidas de segurança aplicáveis a ela são aquelas direcionadas à Secretaria.

3.6. Benefícios estimados

Entre os benefícios estimados desta fiscalização, destacam-se o fortalecimento da governança em segurança da informação nas organizações estaduais, pelo suporte às estruturas de segurança da informação das organizações, aprimoramento na gestão de riscos e na adoção de controles e medidas de segurança alinhadas às boas práticas internacionais do tema.

A auditoria contribui também na promoção de uma cultura organizacional sustentável que induza comportamentos positivos nos indivíduos em relação à proteção de dados e informações corporativas.

Além disso, com base nas propostas de encaminhamento apresentadas, espera-se que os jurisdicionados implementem os planos de ação e elevem seus níveis de maturidade no tema.

3.7. Antecedentes

Foram identificados trabalhos anteriores desta Corte de Contas que tangenciam do tema de segurança da informação abordado na presente fiscalização.

Tabela 1 - Relação de processos fiscalizatórios associados à presente fiscalização

Processo TCE-RJ	Natureza	Objetivo
206.972-5/2022	Relatório de Auditoria Governamental – Auditoria de Conformidade – Ordinária (municipal)	Verificar a conformidade das prefeituras municipais jurisdicionadas à Lei 13.709/2018, conhecida como Lei Geral de Proteção de Dados Pessoais (LGPD).
100.800-1/2022	Relatório de Auditoria Governamental – Auditoria de Conformidade – Ordinária (Estadual)	Verificar a conformidade dos órgãos estaduais à Lei 13.709/2018, conhecida como Lei Geral de Proteção de Dados Pessoais (LGPD).
109.009-4/2023	Relatório de Auditoria Governamental – Auditoria de Conformidade - Ordinária	Verificar os aspectos das políticas de Governança e Gestão de TI enquanto norteadores das contratações de Tecnologia da Informação do Executivo Estadual no âmbito do SETIC, analisando, de forma subsidiária, a regularidade das contratações enquanto reflexo de tais políticas para identificar suas causas e propor medidas para mitigá-las.

100.749-5/2024	Relatório de Auditoria Governamental – Levantamento – Ordinária	Identificar os sistemas de informação críticos da Administração Pública Estadual, que suportam os processos de negócio na Administração, de modo a subsidiar o desenvolvimento de estratégia para fiscalizar tais sistemas, assim como a infraestrutura em que operam.
----------------	---	--

(Fonte: elaboração própria)

Nesse sentido, os processos TCE-RJ nº 206.972-5/2022 e nº 100.800-1/2022 tratam da Lei Geral de Proteção de Dados Pessoais (LGPD), na qual existem dispositivos atinentes à segurança da informação e em cujas auditorias foi calculado o índice de proteção de dados pessoais - IPD.

O processo TCE-RJ nº 109.009-4/2023 trata da governança e gestão de TI nas organizações do Sistema Estadual de Tecnologia da Informação e Comunicação – SETIC do Poder Executivo Estadual. Nesse trabalho foram mensurados indicadores que tratam aspectos de segurança da informação.

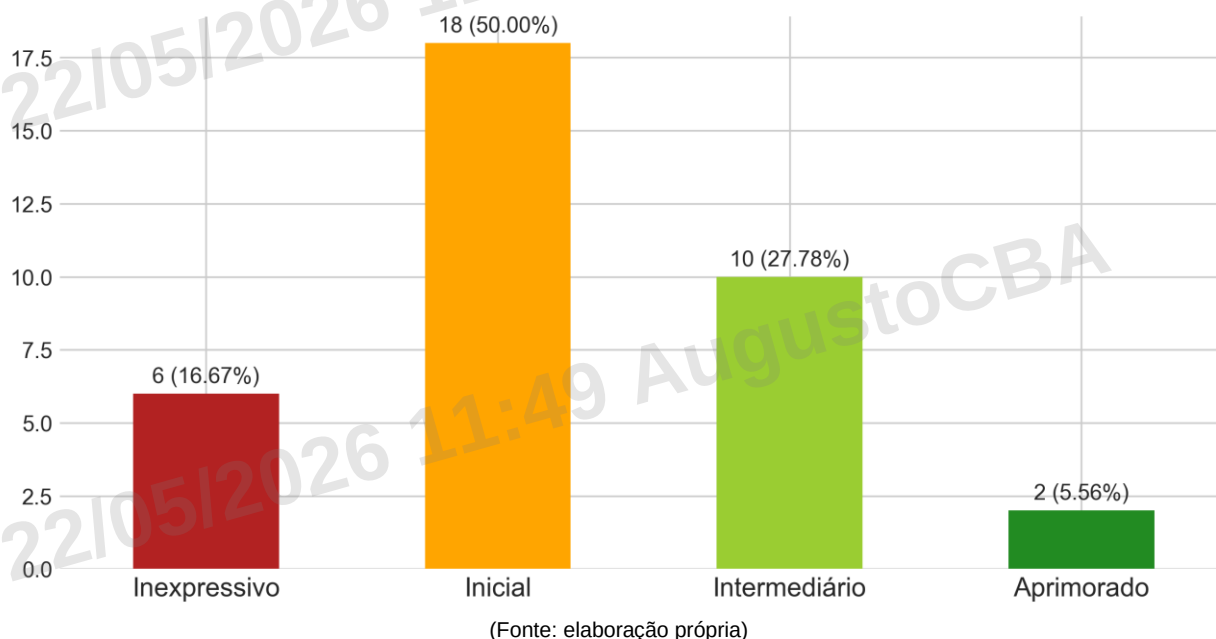
Por fim, o processo TCE-RJ nº 100.749-5/2024 identificou os sistemas críticos da Administração Pública Estadual, mapeando seus impactos e vulnerabilidades mais relevantes. Parte do modelo de criticidade dos sistemas era baseado em critérios de segurança da informação.

4. RESULTADOS DA AUDITORIA

4.1. Análise do índice parcial de adequação às medidas básicas de segurança cibernética das organizações (iSegCiberBase)

As organizações foram classificadas em níveis de maturidade¹³ quanto à adoção das medidas básicas de segurança cibernética. Nessa feita, apresenta-se na Figura 5 a consolidação da distribuição dos níveis das organizações auditadas.

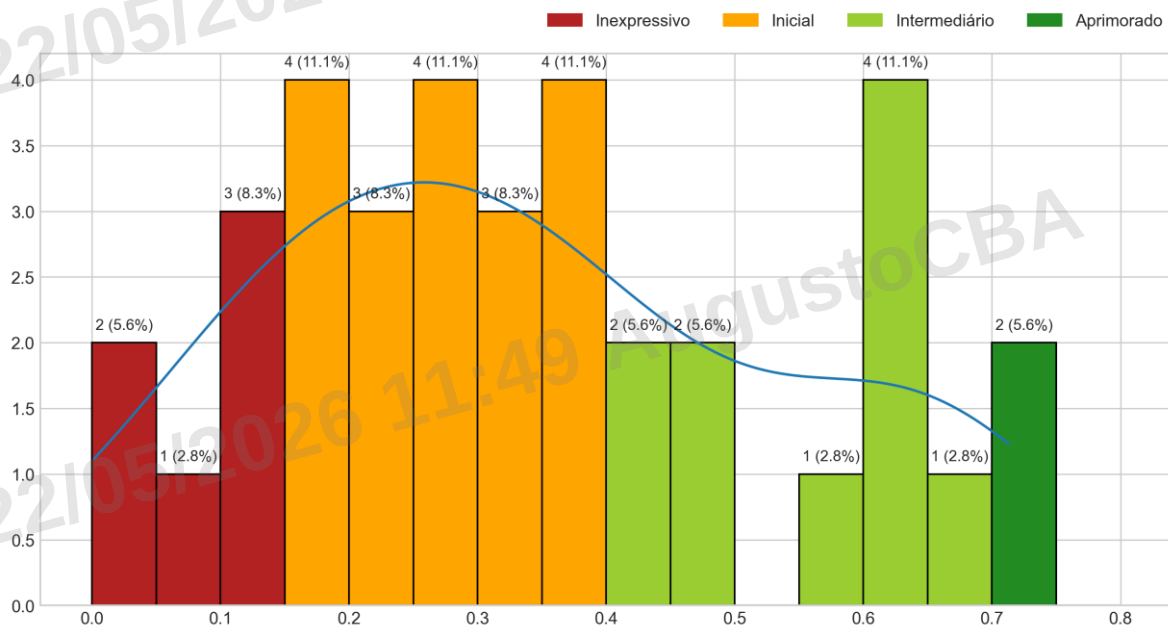
Figura 5 - Níveis de maturidade das organizações às medidas básicas de segurança cibernética



Num aspecto geral, verificou-se que a maior parte das organizações estaduais está no nível inicial de adoção das medidas básicas de segurança cibernética e que entre aqueles que se encontram nesse nível, apresentam-se uniformemente distribuídos no nível de maturidade, conforme pode ser verificado na Figura 6.

¹³ Os níveis de maturidade para classificar as organizações foram definidos em “Inexpressivo” (valor menor ou igual a 0,15), “Inicial” (valor maior do que 0,15 e menor ou igual a 0,4), “Intermediário” (valor maior do que 0,4 e menor ou igual a 0,7) e “Aprimorado” (indicador maior do que 0,7).

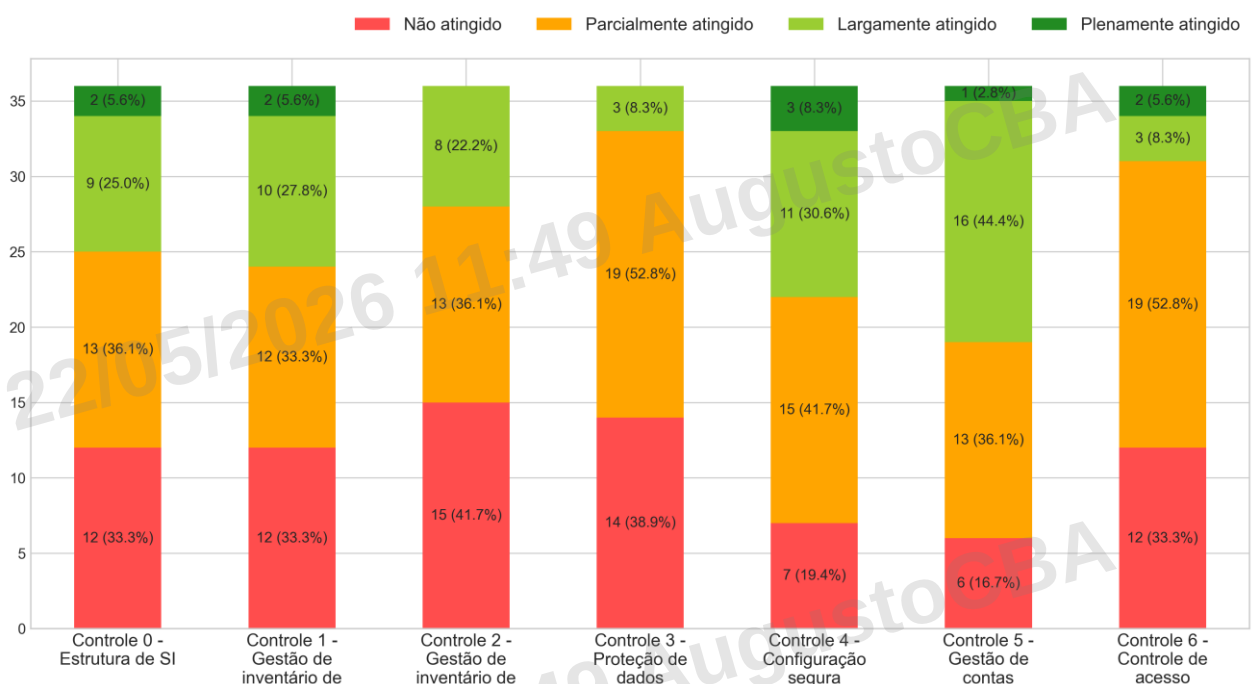
Figura 6 – Histograma apresentando a distribuição do iSegCiberBase pelos níveis de maturidade



(Fonte: elaboração própria)

Observando o cenário geral de adoção dos controles de medidas básicas de segurança da informação e segurança cibernética (Figura 7), observa-se que os controles que ensejam mais atenção por parte das organizações estaduais auditadas foram o Controle 02 de gestão de inventário de softwares e o Controle 03 de proteção de dados.

Figura 7 - Controles de medidas básicas



(Fonte: elaboração própria)

4.2. Achados da auditoria

A segurança da informação e a segurança cibernética consistem em um conjunto integrado de práticas inter-relacionadas que têm como objetivo assegurar a confidencialidade, a integridade e a disponibilidade das informações sob a responsabilidade de uma organização.

Nesse contexto, os achados apresentados nesta auditoria evidenciam falhas que potencialmente comprometem a proteção das informações custodiadas pelas organizações auditadas, resultando em violações aos incisos II e III do art. 6º da Lei de Acesso à Informação (Lei Federal nº 12.527/2011), aos princípios dispostos no art. 3º do Marco Civil da Internet (Lei Federal nº 12.965/2014) e aos arts. 46 e 47 da Lei Geral de Proteção de Dados (Lei Federal nº 13.709/2018), que determinam a adoção de medidas técnicas e administrativas necessárias à proteção dos dados pessoais.

Portanto, ainda que algumas das medidas de segurança não estejam expressamente previstas em normativos federais, estaduais ou intra-organizacionais, tratam-se de práticas essenciais que devem ser adotadas para uma gestão segura e eficaz das informações de uma organização pública.

4.2.1. Achado 1 – Ausência de uma estrutura básica atuante de segurança da informação que estabeleça papéis, políticas e responsabilidades

4.2.1.1. Critérios

- Lei Federal nº 12.527/2011 (LAI), art. 6º, incisos II e III;
- Lei Federal nº 13.709/2018 (LGPD), arts. 6º, inciso VII, 46, 47, 50, § 2º, inciso I, alínea a) e d);
- Norma Técnica ABNT NBR ISO/IEC 27001:2022, itens 5.1 (Liderança e comprometimento), 5.2 (Política), 5.3 (Papéis, responsabilidades e autoridades organizacionais), 6.1 (Ações para abordar riscos e oportunidades), 8 (Operação);
- Resolução TJ/OE nº 28/2022, art. 20;
- Ato Normativo TCE-RJ nº 234/2023;
- Instrução Normativa PRODERJ/PRE nº 02/2022, art. 9º, e 11, inciso VI;
- Instrução Normativa PRODERJ/PRE nº 02/2022, Anexo Único, Item 8.14.1;
- Instrução Normativa GSI/PR nº 01/2020, art. 9º e 15.

4.2.1.2. Evidências

As evidências que embasam este achado para todas as organizações estão no Anexo AN04.

4.2.1.3 Situação Encontrada

A alta direção da organização deve demonstrar^{14,15}, de forma clara, liderança e comprometimento com a gestão de segurança da informação, estabelecendo uma estrutura mínima de gestão de segurança da informação que assegure¹⁶ a confidencialidade, integridade e disponibilidade das informações sob sua responsabilidade.

Além disso, a Lei Geral de Proteção de Dados Pessoais (LGPD), em seus artigos 46 e 47, exige a adoção de medidas de segurança técnicas e administrativas adequadas para a proteção dos dados pessoais. Nesse sentido, as organizações públicas podem utilizar como referência as boas práticas da Norma Técnica ABNT NBR ISO/IEC 27001:2022.

Assim, o estabelecimento de uma estrutura adequada, que (1) defina papéis, responsabilidades e atribuições, (2) aplique um processo de gestão de riscos e (3) estabeleça e mantenha a Política de Segurança da Informação, representa o mínimo para preservar a confidencialidade, integridade e disponibilidade das informações sob responsabilidade da Administração e cumprir os dispositivos legais da LGPD e da Lei de Acesso à Informação (LAI).

¹⁴ O item 5.1 da Norma Técnica ABNT NBR ISO/IEC 27001:2022 dispõe sobre os meios que a Alta Administração da organização deve seguir para demonstrar sua liderança e comprometimento com o sistema de gestão da segurança da informação - SGSI, entre os quais ressaltam-se a garantia da existência de uma política de segurança da informação alinhadas com o contexto organizacional, bem como assegurando os recursos necessários para o SGSI.

¹⁵ A LGPD (Lei Federal nº 13.709/2018), em seu art. 50, § 2º, inciso I, alínea a) e d), expressa requisitos mínimos a serem adotados pelos controladores em seus programas de governança em privacidade, quais sejam:

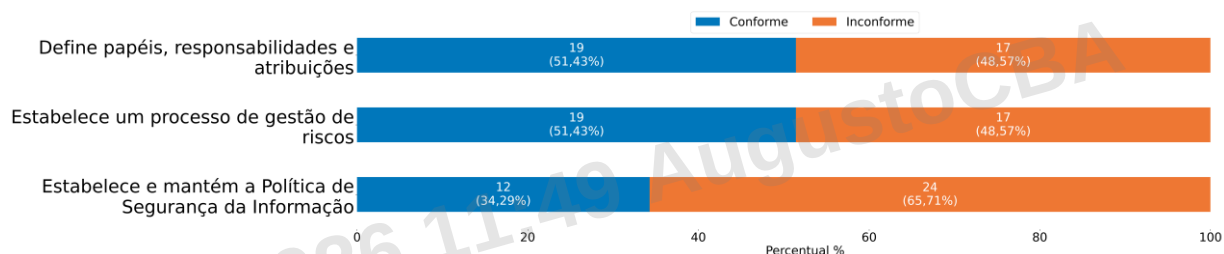
a) demonstre o comprometimento do controlador em adotar processos e políticas internas que assegurem o cumprimento, de forma abrangente, de normas e boas práticas relativas à proteção de dados pessoais;
d) estabeleça políticas e salvaguardas adequadas com base em processo de avaliação sistemática de impactos e riscos à privacidade;

¹⁶ Lei Federal nº 12.527/2011 (LAI)

Art. 6º Cabe aos órgãos e entidades do poder público, observadas as normas e procedimentos específicos aplicáveis, assegurar a: [...] II - proteção da informação, garantindo-se sua disponibilidade, autenticidade e integridade; e III - proteção da informação sigilosa e da informação pessoal, observada a sua disponibilidade, autenticidade, integridade e eventual restrição de acesso.

Nesse contexto, com base na análise dos itens 0002, 0003, 0004 e 0005 do Questionário submetido pelo TSID02, a Equipe de Auditoria identificou o seguinte panorama (Figura 8):

Figura 8 – Distribuição das práticas que estabelecem uma estrutura adequada de segurança da informação



(Fonte: elaboração própria)

Essas situações ensejaram o presente achado e serão detalhadas nas seções subsequentes.

Responsável pela segurança da informação

Conforme os itens 5.1 e 5.3 da Norma Técnica ABNT NBR ISO/IEC 27001:2022, a organização deve demonstrar seu comprometimento com a segurança da informação, garantindo que os recursos necessários para sua gestão estejam disponíveis e assegurando que as responsabilidades e autoridades dos papéis relevantes para a segurança da informação sejam devidamente atribuídas e comunicadas internamente.

Essa boa prática já foi incorporada a normativos de diferentes poderes e esferas da Administração Pública. Exemplos incluem o art. 11, inciso VI, da Instrução Normativa PRODERJ/PRE nº 02/2022, aplicável ao Poder Executivo do Estado do Rio de Janeiro, o art. 15 da Instrução Normativa GSI/PR nº 01/2020, no âmbito do Poder Executivo Federal, o art. 20 da Resolução TJ/OE nº 28/2022, aplicável ao TJRJ, e o art. 2º do Ato Normativo TCE-RJ nº 234/2023, aplicável ao TCE-RJ.

A ausência de uma pessoa responsável pela gestão da segurança da informação representa um risco significativo, pois pode comprometer a implementação das práticas necessárias para mitigar os riscos existentes.

Nessa feita, a Equipe de Auditoria analisou a resposta ao item 0002 do questionário submetido pelo TSID02, a documentação remetida como anexo à resposta, e os comentários do gestor, para averiguar a existência de um Gestor para a segurança da informação da organização ou responsável equivalente.

Da análise das respostas e evidências, conforme ilustrado na Figura 8, verificou-se que 17 (48,57%) das 36 organizações auditadas não possuem um responsável pela segurança da informação.

Diante disso, será sugerida proposta de encaminhamento às organizações nessa situação para que assegurem que as responsabilidades e autoridades relativas à segurança da informação sejam devidamente estabelecidas, atribuídas e comunicadas.

Gestão de riscos de segurança da informação

Segundo os itens 6.1 e 8 da Norma Técnica ABNT NBR ISO/IEC 27001:2022, a organização deve implementar um processo de gestão de riscos com o objetivo de preservar a confidencialidade, integridade e disponibilidade das informações sob sua responsabilidade.

Esse processo deve contemplar as etapas de identificação, avaliação, tratamento e monitoramento dos riscos de segurança da informação que possam representar ameaças à organização.

Nesse contexto, a LGPD, na alínea d), inciso I, § 2º do art. 50, aponta como requisito mínimo do programa de governança em privacidade da organização que se estabeleçam políticas e salvaguardas adequadas com base em um processo de avaliação sistemática de impactos e riscos à privacidade.

No âmbito das organizações do Executivo Estadual, o item 8.14.1 do anexo único da Instrução Normativa PRODERJ/PRE nº 02/2022, dispõe sobre o dever de o Gestor de Segurança da Informação analisar, avaliar e tratar os riscos de segurança da informação.

A ausência de um processo estruturado de gestão de riscos expõe a organização a vulnerabilidades significativas, incluindo a possibilidade de não tratar riscos críticos que podem comprometer as informações e a continuidade de suas atividades.

Nessa feita, a Equipe de Auditoria analisou a resposta ao item 0003 do questionário submetido pelo TSID02 e os comentários do gestor, para averiguar a adoção de um processo de gestão de riscos de segurança da informação.

Da análise das respostas, conforme ilustrado Figura 8, verificou-se que 17 (48,57%) das 36 organizações auditadas não gerenciam os riscos de segurança da informação.

Diante disso, será sugerida proposta de encaminhamento às organizações nessa situação para que estabeleçam um processo de gestão de riscos alinhado ao seu contexto organizacional, a fim de identificar, avaliar e tratar os riscos de segurança da informação.

Política de Segurança da Informação

De acordo com os itens 5.1 e 5.2 da Norma Técnica ABNT NBR ISO/IEC 27001:2022, a organização deve estabelecer a Política de Segurança da Informação – PSI e assegurar que ela esteja alinhada às necessidades da organização e disponível como informação documentada às partes interessadas.

A ausência de uma PSI prejudica a padronização de regras gerais sobre segurança da informação na organização e dificulta a atribuição clara de responsabilidades para sua gestão, impactando a agilidade na resposta aos incidentes.

Alinhando-se ao entendimento da ISO 27001 sobre a necessidade da PSI, a LGPD, na alínea a), inciso I, § 2º do art. 50, aponta como requisito mínimo do programa de governança em privacidade que se demonstre o comprometimento em adotar processos e políticas internas que assegurem o cumprimento, de forma abrangente, de normas e boas práticas relativas à proteção de dados pessoais.

Ademais, o dever de elaborar e manter uma PSI já foi objeto de reiteradas decisões desta Corte de Contas como nos Acórdãos nº 10.168/2023-PLENV, 36.218/2023-PLENV e 18.601/2024-PLENV.

Nessa feita, a Equipe de Auditoria analisou a resposta ao item 0004 do questionário submetido pelo TSID02, a documentação remetida como anexo à resposta, e os comentários do gestor, para averiguar se a organização estabelece e mantém uma PSI.

Da análise das respostas e evidências, conforme ilustrado na Figura 8, verificou-se que 24 (65,71%) das 36 organizações auditadas não possuem uma Política de Segurança da Informação – PSI estabelecida e mantida.

Diante disso, será sugerida proposta de encaminhamento às organizações nessa situação para que estabeleçam e mantenham uma Política de Segurança da Informação aprovada pela autoridade máxima da organização e elaborada considerando a natureza e o contexto organizacional, definindo princípios, diretrizes, procedimentos e responsabilidades, a ser revisada, no máximo, a cada quatro anos.

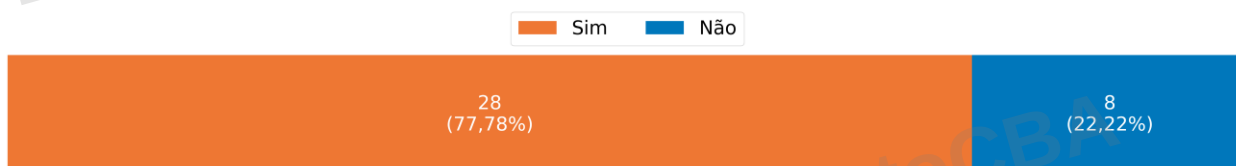
Conclusão

Os procedimentos executados nesta seção foram desenvolvidos para responder à questão de auditoria nº 1, qual seja:

Q1. As organizações possuem uma estrutura básica atuante de segurança da informação que estabelece papéis, políticas e responsabilidades?

Com base nas situações avaliadas, verificou-se, como pode ser visto na Figura 9, que 28 (77,78%) das 36 organizações auditadas não possuem uma estrutura básica atuante de segurança da informação.

Figura 9 – Quantitativo de organizações contidas no achado 1



(Fonte: elaboração própria)

Diante disso, serão sugeridas propostas de encaminhamento às organizações para que se estruturem de maneira adequada, aos moldes da ABNT NBR ISO/IEC 27001:2022, visando o aprimoramento da sua gestão de segurança da informação.

4.2.1.4 Causas

- Não investigadas.

4.2.1.5 Efeitos

- Descontinuidade ou omissão das ações de gestão (planejar, executar, controlar e agir) da segurança da informação;

4.2.1.6 Propostas de Encaminhamento

Ressalta-se que as propostas de encaminhamento individualizadas para cada organização auditada constam no bojo dos relatórios individuais presentes nos conjuntos

de anexos AN08 a AN43. Dessa forma, seguem as sugestões gerais propostas pela Equipe de Auditoria:

- **Comunicação com Determinação** às organizações que não possuem responsáveis pela segurança da informação para que assegurem que as responsabilidades e autoridades relativas à segurança da informação sejam devidamente estabelecidas, atribuídas e comunicadas;
- **Comunicação com Determinação** às organizações que não gerenciam os riscos de segurança da informação para que estabeleçam um processo de gestão de riscos alinhado ao seu contexto organizacional, a fim de identificar, avaliar e tratar os riscos de segurança da informação;
- **Comunicação com Determinação** às organizações que não possuem uma Política de Segurança da Informação adequada para que estabeleçam e mantenham uma Política de Segurança da Informação aprovada pela autoridade máxima da organização e elaborada considerando a natureza e o contexto organizacional, definindo princípios, diretrizes, procedimentos e responsabilidades, a ser revisada, no máximo, a cada quatro anos.

4.2.2. Achado 2 – Medidas básicas de segurança cibernética insuficientes na gestão ativa dos ativos corporativos e softwares

4.2.2.1. Critérios

- Lei Federal nº 12.527/2011 (LAI), art. 6º, incisos II e III;
- Lei Federal nº 13.709/2018 (LGPD), art. 6º, inciso VII, 46 e 47;
- Norma Técnica ABNT NBR ISO/IEC 27002:2022, item 5.9 (Inventário de informações e outros ativos associados);
- Controles CIS versão 8, medidas de segurança 1.1 (Estabelecer e manter um inventário detalhado de ativos corporativos), 1.2 (Endereçar ativos não autorizados), 2.1 (Estabelecer e manter um inventário de *software*), 2.2 (Assegurar que o *software* autorizado seja atualmente suportado) e 2.3 (Endereçar o *software* não autorizado);
- Instrução Normativa PRODERJ/PRE nº 02/2022, Anexo Único, Item 8.13.1.1;
- Resolução TJ/OE nº 28/2022, art. 22, inciso II;

- Resolução CNMP nº 294/2024, art. 23, §3º, incisos II, III e IV;
- Instrução Normativa GSI/PR nº 3/2021, arts. 4º ao 9º.

4.2.2.2. Evidências

As evidências que embasam este achado para todas as organizações estão no Anexo AN04.

4.2.2.3 Situação Encontrada

A organização deve estabelecer um processo para gerenciar ativamente seus ativos e *softwares* corporativos. A adoção de uma gestão ativa e estruturada desses ativos permite identificar, monitorar, corrigir e, se necessário, remover dispositivos e *softwares* não autorizados, não gerenciados ou não suportados, reduzindo significativamente os riscos de segurança.

Um aspecto fundamental do gerenciamento de ativos é que não é possível proteger o que não se conhece. Por isso, o inventário de ativos se apresenta como um elemento essencial para a segurança da informação.

Conforme já apontado, a Lei de Acesso à Informação (LAI), em seu art. 6º, incisos II e III, exige que a organização assegure a confidencialidade, integridade e disponibilidade da informação. Adicionalmente, a Lei Geral de Proteção de Dados Pessoais (LGPD), nos artigos 46 e 47, exige a adoção de medidas de segurança técnicas e administrativas adequadas para a proteção dos dados pessoais.

Essas exigências podem ser asseguradas, no contexto da gestão de ativos, adotando-se o item¹⁷ 5.9 da Norma Técnica ISO/IEC 27002:2022 e as ações das medidas básicas¹⁸ de segurança cibernética 1.1, 1.2, 2.1, 2.2 e 2.3 dos Controles CIS versão 8.

Nesse sentido, as medidas básicas (de higiene cibernética) dos Controles 01 e 02 dos Controles CIS versão 8 representam um conjunto mínimo de práticas necessárias

¹⁷ O item 5.9 da ISO/IEC 27002:2022 recomenda que a organização desenvolva e mantenha um inventário de informações e outros ativos associados. Os ativos devem ser identificados e terem sua importância determinada, a fim de preservar sua segurança da informação. Recomenda ainda que o inventário seja preciso, atualizado, consistente e alinhado a outros inventários.

¹⁸ As medidas básicas do Controle 01 (Inventário e controle de ativos corporativos) e do Controle 02 (Inventário e controle de ativos de *software*) dos Controles CIS versão 8 representam o conjunto mínimo de medidas para estabelecer e manter os inventários de *softwares* e de ativos corporativos da organização.

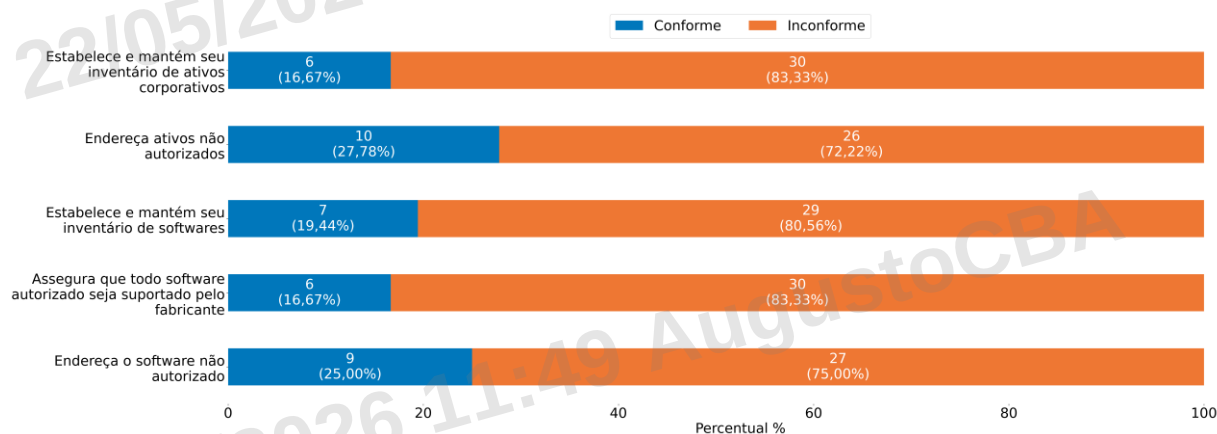
para preservar a confidencialidade, integridade e disponibilidade das informações sob responsabilidade da Administração, além de atender aos dispositivos legais citados.

A gestão de ativos já foi incorporada, sob diferentes aspectos, a normativos de diversos poderes e esferas da Administração Pública. Exemplos¹⁹ incluem a Instrução Normativa GSI/PR nº 03/2021, aplicável ao Poder Executivo Federal, que, em seus artigos 4º a 9º, aborda o dever dos gestores de realizar o mapeamento dos ativos organizacionais, e o tratamento disposto no item 8.13.1.1 do Anexo Único da Instrução Normativa PRODERJ/PRE nº 02/2022, aplicável ao Poder Executivo do Estado do Rio de Janeiro.

Para executar uma gestão ativa adequada dos *softwares* e ativos corporativos, a organização deve, no mínimo, (1) estabelecer e manter um inventário detalhado de *softwares* e ativos corporativos, (2) tratar os *softwares* e ativos não autorizados identificados e (3) assegurar que todo *software* autorizado seja suportado pelo fabricante.

Assim, com base na análise dos itens 0101, 0102, 0201, 0202 e 0203 do Questionário submetido pelo TSID02, a Equipe de Auditoria identificou o seguinte panorama (Figura 10):

Figura 10 – Distribuição das práticas da gestão ativa de softwares e ativos corporativos



(Fonte: elaboração própria)

Essas situações ensejaram o presente achado e serão detalhadas nas seções subsequentes.

¹⁹ Outros dispositivos normativos que tratam de gestão de ativos são o art. 22, inciso II, da Resolução TJ/OE nº 28/2022, aplicável ao TJRJ, e os princípios dispostos nos incisos II, III e IV, do §3º, do art. 23, da Resolução CNMP nº 294/2024, aplicável aos Ministérios Públicos.

Inventário de ativos e *softwares* corporativos

No contexto da gestão ativa, inicialmente, é necessário que a organização estabeleça e mantenha um inventário de *softwares* e ativos corporativos, identificando, registrando e monitorando os ativos existentes em sua infraestrutura.

As medidas de segurança 1.1 e 2.1 dos Controles CIS versão 8 apresentam diretrizes e ações específicas de como elaborar esses inventários, tais como quais dispositivos rastrear e os atributos a serem registrados e monitorados.

Complementando essas ações, o item 5.9 da Norma Técnica ABNT NBR ISO/IEC 27002:2022 dispõe que a organização deve identificar suas informações e ativos associados, bem como determinar sua importância no contexto da segurança da informação. Além disso, o inventário deve ser preciso, atualizado e consistente com os ativos e *softwares* da organização.

Para assegurar essa exatidão, devem ser realizadas análises críticas regulares e utilizadas ferramentas automatizadas para manter as informações do inventário atualizadas.

Dessa forma, o inventário é fundamental para que a organização tenha visibilidade de sua situação atual e sua inexistência prejudica a adoção das demais medidas de segurança, sujeitando a organização ao risco de conviver em sua infraestrutura com ativos e *softwares* não autorizados, não gerenciados e não suportados.

Considerando as práticas apresentadas, a Equipe de Auditoria analisou as respostas aos itens 0101 e 0201 do questionário submetido pelo TSID02, a documentação remetida como anexo à resposta e os comentários do gestor, para averiguar a existência nas organizações de inventários adequados de *softwares* e ativos corporativos.

Da análise das respostas e evidências, conforme ilustrado na Figura 10, verificou-se que 30 (83,33%) das 36 organizações auditadas não estabelecem e mantêm um inventário adequado de ativos corporativos e que 29 (80,56%) das 36 organizações auditadas não estabelecem e mantêm um inventário adequado de *softwares*.

Diante disso, será sugerida proposta de encaminhamento às organizações nessa situação para que estabeleçam, mantenham e revisem periodicamente inventários precisos, detalhados e atualizados dos softwares e ativos corporativos.

Tratamento de ativos e *softwares* não autorizados

Uma vez que a organização estabeleça e mantenha um inventário detalhado e atualizado dos *softwares* e ativos corporativos, cabe à organização realizar o devido tratamento aos ativos não autorizados quando identificados.

As medidas de segurança 1.2 e 2.3 dos Controles CIS versão 8 apresentam diretrizes e ações específicas de como endereçar os *softwares* e ativos não autorizados.

A ocorrência de ativos e *softwares* não autorizados no perímetro das organizações aumentam a superfície e as chances de ataque por terceiros, uma vez que são ativos não gerenciados pela organização e podem ser usados como vetores de ataques ao conter vulnerabilidades, *exploits*²⁰ e *malwares*²¹.

Devem, portanto, ser identificados e devidamente tratados, removendo-os, negando-os acesso ou colocando-os em quarentena.

Considerando as práticas apresentadas, a Equipe de Auditoria analisou as respostas aos itens 0102 e 0203 do questionário submetido pelo TSID02 e os comentários do gestor, para averiguar se os *softwares* e ativos não autorizados são tratados.

Da análise das respostas, conforme ilustrado na Figura 10, verificou-se que 26 (72,22%) das 36 organizações auditadas não tratam adequadamente os ativos corporativos não autorizados e que 27 (75%) delas não tratam adequadamente os *softwares* não autorizados.

Diante disso, será sugerida proposta de encaminhamento às organizações nessa situação para que estabeleçam um processo para tratar os *softwares* e ativos corporativos não autorizados.

Softwares autorizados são suportados

Por fim, assim como a ocorrência de ativos e *softwares* não autorizados configuram-se como riscos à organização, a existência de *softwares* autorizados que não tenham mais suporte do fabricante, também, são fontes de ameaças à organização e devem ser tratados. Esses ativos não possuem mais manutenção, correção de *bugs*, *exploits* e vulnerabilidades, e tendem a se tornar obsoletos e vulneráveis a ataques.

²⁰ *Exploit* é um método ou código projetado para explorar uma vulnerabilidade em sistemas, *softwares* ou dispositivos, não é, por si só, um programa malicioso, mas sim uma técnica usada por atacantes para obter acesso não autorizado, executar comandos, ou causar outros danos.

²¹ *Malware* (abreviação de *malicious software*) refere-se a qualquer programa ou código desenvolvido com a intenção de causar danos, roubar informações, ou comprometer a integridade de sistemas e redes.

A medida de segurança 2.2 dos Controles CIS versão 8 apresenta diretrizes e ações específicas de como a organização deve assegurar que os *softwares* autorizados tenham o devido suporte, registrando os casos de exceção identificados.

Considerando as práticas apresentadas, a Equipe de Auditoria analisou as respostas ao item 0202 do questionário submetido pelo TSID02 e os comentários do gestor, para averiguar se os *softwares* autorizados são suportados pelo fabricante.

Da análise das respostas, conforme ilustrado na Figura 10, verificou-se que 30 (83,33%) das 36 organizações auditadas não asseguram que os *softwares* autorizados sejam suportados pelo fabricante.

Diante disso, será sugerida proposta de encaminhamento às organizações nessa situação para que revisem mensalmente os *softwares* autorizados do inventário afim de verificar se eles ainda possuem suporte.

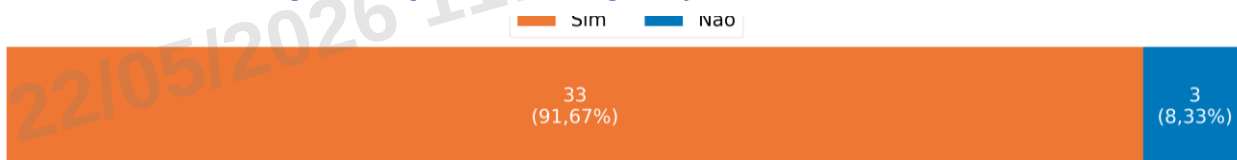
Conclusão

Os procedimentos executados nesta seção foram desenvolvidos para responder à questão de auditoria nº 2, qual seja:

Q2. As organizações adotam as medidas básicas de higiene cibernética para gerenciar ativamente os ativos corporativos conectados à sua infraestrutura e os *softwares* utilizados conforme disposto nos Controles 1 e 2 do CIS Controles 8?

Com base nas situações avaliadas, verificou-se, como pode ser visto na Figura 11, que 33 (91,67%) das 36 organizações auditadas não adotam adequadamente as medidas básicas de segurança cibernética dispostas nos Controles 1 e 2 dos Controles CIS versão 8.

Figura 11 – Quantitativo de organizações contidas no achado 3



(Fonte: elaboração própria)

Diante disso, serão sugeridas propostas de encaminhamento às organizações para que gerenciem adequada e ativamente seus ativos corporativos e *softwares* aos moldes da ABNT NBR ISO/IEC 27002:2022 e das medidas de segurança básicas dos Controles CIS v8.

4.2.2.4 Causas

- Não investigadas.

4.2.2.5 Efeitos

- Falha na garantia do tratamento adequado dos softwares não autorizados;
- Possível existência de dispositivos desconhecidos, não monitorados, não autorizados e não protegidos adequadamente;
- Utilização de *softwares* desconhecidos, comprometidos e vulneráveis impactando a segurança cibernética da organização por um aumento da superfície de ataque;
- Utilização de *softwares* não mais suportados pelo fabricante (software legado, *deprecated*), possivelmente com brechas de segurança não tratadas ou mitigadas

4.2.2.6 Propostas de Encaminhamento

Ressalta-se que as propostas de encaminhamento individualizadas para cada organização auditada constam no bojo dos relatórios individuais presentes nos conjuntos de anexos AN08 a AN43. Dessa forma, seguem as sugestões gerais propostas pela Equipe de Auditoria:

- **Comunicação com Recomendação** às organizações que não possuem inventário adequado de ativos corporativos para que adotem integralmente a medida de segurança 1.1 (Estabelecer e manter um inventário detalhado de ativos corporativos) prevista nos Controles CIS v8, atentando-se, minimamente, em estabelecer, manter e revisar periodicamente um inventário preciso, detalhado e atualizado de todos os ativos corporativos conectados à infraestrutura física, virtual ou remotamente;
- **Comunicação com Recomendação** às organizações que não tratam adequadamente os ativos não autorizados para que adotem integralmente a medida de segurança 1.2 (Endereçar ativos não autorizados) prevista nos Controles CIS v8, atentando-se, minimamente, em estabelecer um processo para lidar com ativos não autorizados com periodicidade semanal, removendo-os da rede, negando-os acesso ou colocando-os em quarentena, quando identificados;

- **Comunicação com Recomendação** às organizações que não possuem inventário adequado de softwares para que adotem integralmente a medida de segurança 2.1 (Estabelecer e manter um inventário de software) prevista nos Controles CIS v8, atentando-se, minimamente, em estabelecer, manter e revisar periodicamente um inventário preciso, detalhado e atualizado dos *softwares* instalados nos ativos corporativos;
- **Comunicação com Recomendação** às organizações que não asseguram que os softwares autorizados sejam suportados pelo fabricante para que adotem integralmente a medida de segurança 2.2 (Assegurar que o *software* autorizado seja atualmente suportado) prevista nos Controles CIS v8, atentando-se, minimamente, em revisar mensalmente os softwares autorizados do inventário afim de verificar se eles ainda possuem suporte;
- **Comunicação com Recomendação** às organizações que não tratam adequadamente os softwares não autorizados para que adotem integralmente a medida de segurança 2.3 (Endereçar o *software* não autorizado) prevista nos Controles CIS v8, atentando-se, minimamente, em revisar mensalmente os softwares instalados nos ativos corporativos, a fim de remover os softwares não autorizados identificados;

4.2.3. Achado 3 – Medidas básicas de segurança cibernética insuficientes na proteção dos dados da organização

4.2.3.1. Critérios

- Lei Federal nº 12.527/2011 (LAI), art. 6º, incisos II e III;
- Lei Federal nº 13.709/2018 (LGPD), art. 6º, inciso VII, 46 e 47;
- Norma Técnica ABNT NBR ISO/IEC 27002:2022, itens 5.9 (Inventário de informações e outros ativos associados) e 5.10 (Uso aceitável de informações e outros ativos associados);
- Controles CIS versão 8, medidas de segurança 3.1 (Estabelecer e manter um processo de gestão de dados), 3.2 (Estabelecer e manter um inventário de dados), 3.3 (Configurar listas de controle de acesso a dados), 3.4 (Aplicar retenção de

dados), 3.5 (Descartar dados com segurança) e 3.6 (Criptografar dados em dispositivos de usuário final).

- Instrução Normativa PRODERJ/PRE nº 02/2022, Anexo Único, Itens 7.5 e 7.6;
- Resolução TJ/OE nº 28/2022, art. 9º, incisos II e V.

4.2.3.2. Evidências

As evidências que embasam este achado para todas as organizações estão no Anexo AN04.

4.2.3.3 Situação Encontrada

A proteção de dados foi regulamentada no âmbito dos dados pessoais pela Lei Geral de Proteção de Dados Pessoais (LGPD) que regulamenta as hipóteses e requisitos a serem seguidos no tratamento de dados pessoais.

O princípio da segurança, disposto no art. 6º, VII, da norma, alinhando-se aos artigos 46 e 47, dispõe que as atividades de tratamento devem observar a “utilização de medidas técnicas e administrativas aptas a proteger os dados pessoais de acessos não autorizados e de situações acidentais ou ilícitas de destruição, perda, alteração, comunicação ou difusão”.

De forma análoga, a Lei de Acesso à Informação (LAI), no art. 6º, incisos II e III, exige que as organizações públicas assegurem a confidencialidade, integridade e disponibilidade das informações sob sua responsabilidade.

Para o âmbito estadual, destaca-se o art. 9º, incisos II e V, da Resolução TJ/OE nº 28/2022, aplicável ao TJRJ, dispondo que a Política de Segurança da Informação deve estabelecer controles para o tratamento de informações e utilizar soluções de criptografia. Outro exemplo são os itens 7.5 e 7.6 do Anexo Único da Instrução Normativa PRODERJ/PRE nº 02/2022 que apresentam as responsabilidades do controlador e operador de dados.

Essas exigências legais podem ser minimamente asseguradas adotando-se as orientações dos itens²² 5.9 e 5.10 da Norma Técnica ISO/IEC 27002:2022 e as ações

²² Como já mencionado, o item 5.9 da Norma Técnica ABNT NBR ISO/IEC 27002:2022 recomenda que a organização desenvolva e mantenha um inventário de informações e outros ativos associados. As informações devem ser identificados e terem sua importância determinada, a fim de preservar sua segurança da informação. Recomenda ainda que o inventário seja preciso, atualizado, consistente e alinhado a outros inventários.

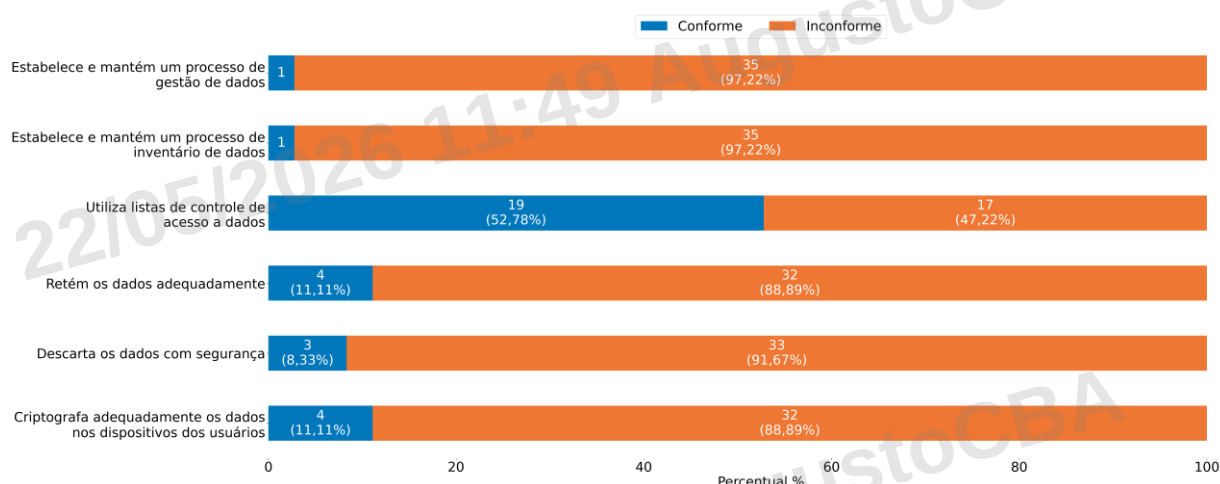
das medidas básicas²³ de segurança cibernética 3.1, 3.2, 3.3, 3.4, 3.5 e 3.6 dos Controles CIS versão 8.

Para assegurar a proteção dos dados, as organizações devem desenvolver processos e controles técnicos para identificar, classificar, tratar, reter e descartar seus dados e informações.

Dessa forma, verifica-se que, para executar uma proteção de dados adequada, a organização deve, no mínimo, (1) estabelecer e manter um processo de gestão de dados, (2) estabelecer e manter um inventário de dados, (3) configurar e utilizar listas de controle para acesso aos dados, (4) realizar a adequada retenção e descarte dos dados, e (5) criptografar dispositivos de usuário final que contenham dados sensíveis.

Assim, com base na análise dos itens 0301, 0302, 0303, 0304, 0305 e 0306 do Questionário submetido pelo TSID02, a Equipe de Auditoria identificou o seguinte panorama (Figura 12):

Figura 12 – Distribuição das práticas da proteção de dados



(Fonte: elaboração própria)

Essas situações ensejaram o presente achado e serão detalhadas nas seções subsequentes.

Processo de gestão de dados

²³ As medidas básicas do Controle 03 (Proteção de dados) dos Controles CIS versão 8 apontam a importância de a organização realizar a gestão de seus dados, da coleta ao descarte, desenvolvendo processos e controles técnicos para identificar, classificar, tratar, reter e descartar os dados.

Um processo robusto de gestão de dados é fundamental para garantir que os dados sejam tratados de maneira organizada, segura e em conformidade com as políticas e regulamentações aplicáveis. Os dados devem ser gerenciados de maneira adequada em todo seu ciclo de vida, desde a coleta até o descarte.

A privacidade de dados tornou-se cada vez mais importante e as empresas estão aprendendo que ela diz respeito ao uso e à gestão apropriada dos dados, não apenas à criptografia.

A ausência de um processo de gestão de dados pode expor a organização a uma série de riscos críticos, como vazamento de dados e descumprimento legal.

Nessa feita, a medida de segurança 3.1 dos Controles CIS versão 8 apresenta diretrizes e ações específicas de como estabelecer e manter um processo de gestão de dados.

Complementando essas ações, o item 5.10 da Norma Técnica ABNT NBR ISO/IEC 27002:2022 recomenda que as regras para o uso aceitável e para o tratamento das informações sejam identificadas, documentadas e implementadas.

Considerando as práticas apresentadas, a Equipe de Auditoria analisou as respostas do item 0301 do questionário submetido pelo TSID02, a documentação remetida como anexo às respostas e os comentários do gestor, para averiguar a existência do processo de gestão de dados da organização.

Da análise das respostas e evidências, conforme ilustrado na Figura 12, verificou-se que 35 (91,7%) das 36 organizações auditadas não estabelecem e mantêm um processo de gestão de dados adequado.

Diante disso, será sugerida proposta de encaminhamento às organizações nessa situação para que estabeleçam, mantenham e revisem periodicamente um processo de gestão de dados que considere a sensibilidade dos dados, o proprietário dos dados, o tratamento dos dados, os limites de retenção de dados e os requisitos de descarte.

Inventário de dados

O inventário de dados é essencial para garantir o controle e a proteção das informações sensíveis da organização. Esse inventário é base para implementar medidas de segurança adequadas e para a conformidade com normas e regulamentações que exigem a gestão organizada dos dados.

Nesse contexto, a medida de segurança 3.2 dos Controles CIS versão 8 apresenta diretrizes e ações específicas de como estabelecer e manter um inventário de dados.

Alinhando-se a essa medida, o item 5.9 da Norma Técnica ABNT NBR ISO/IEC 27002:2022 recomenda que a organização desenvolva e mantenha um inventário de informações. As informações devem ser identificadas e terem sua importância determinada, a fim de preservar sua segurança da informação. Recomenda ainda que o inventário seja preciso, atualizado, consistente e alinhado a outros inventários.

Considerando a prática apresentada, a Equipe de Auditoria analisou as respostas do item 0302 do questionário submetido pelo TSID02, a documentação remetida como anexo à resposta, e os comentários do gestor, para averiguar a existência nas organizações de inventários adequados de *softwares* e ativos corporativos.

Da análise das respostas e das evidências, conforme ilustrado na Figura 12, verificou-se que 35 (91,7%) das 36 organizações auditadas não estabelecem e mantêm um inventário de dados adequado.

Diante disso, será sugerida proposta de encaminhamento às organizações nessa situação para que estabeleçam, mantenham e revisem periodicamente um inventário de dados com base no processo de gestão de dados da organização.

Listas de controle de acesso

A adoção das listas de controle de acesso (ACLs) configura-se como importante ferramenta para assegurar que somente indivíduos ou sistemas autorizados tenham acesso aos dados necessários para desempenhar suas funções. As ACLs são ferramentas básicas, mas poderosas, para implementar o princípio de menor privilégio, reduzindo o risco de acesso indevido.

Nesse contexto, a medida de segurança 3.3 dos Controles CIS versão 8 apresenta diretrizes e ações específicas a serem seguidas ao configurar as listas de controle de acesso a dados.

Considerando a prática apresentada, a Equipe de Auditoria analisou as respostas do item 0303 do questionário submetido pelo TSID02 e os comentários do gestor, para averiguar se as organizações configuram e utilizam as listas de controle de acesso a dados.

Da análise das respostas, conforme ilustrado na Figura 12, verificou-se que 17 (47,22%) das 36 organizações auditadas não adotam a prática.

Diante disso, será sugerida proposta de encaminhamento às organizações nessa situação para que configurem e utilizem listas de controle de acesso (ACLs) a dados com base na necessidade de conhecimento de cada usuário, aplicando-as para controlar o acesso a sistemas de arquivos, bancos de dados e sistemas locais e remotos.

Retenção adequada e descarte seguro dos dados

No contexto da proteção de dados, a retenção adequada e o descarte seguro dos dados são complementares e fundamentais para uma gestão eficaz dos dados.

A primeira é essencial para garantir que as organizações armazenem informações somente pelo período necessário ao cumprimento de seus objetivos operacionais, legais e regulatórios, alinhando-se aos dispositivos da LGPD (Lei Federal nº 13.709/2018). Essa prática previne o acúmulo desnecessário de dados, reduzindo riscos de segurança e otimizando os recursos disponíveis.

Já o descarte seguro dos dados permite que dados desnecessários sejam descartados de maneira segura, eliminando o risco de recuperação por terceiros mal-intencionados. O descarte seguro é tão importante quanto a proteção de dados armazenados, especialmente para informações sensíveis ou confidenciais.

Ambas as atividades são importantes do ponto de vista de segurança da informação e não devem ser ignoradas pelos gestores de segurança das organizações.

As medidas de segurança 3.4 e 3.5 dos Controles CIS versão 8 apresentam orientações de como essas práticas podem ser adotadas pelas organizações.

Considerando as práticas apresentadas, a Equipe de Auditoria analisou as respostas do item 0304 e 0305 do questionário submetido pelo TSID02 e os comentários do gestor, para averiguar se as organizações aplicam a retenção adequada dos dados, bem como seu descarte seguro.

Da análise das respostas, conforme ilustrado na Figura 12, verificou-se que 32 (88,9%) das 36 organizações auditadas não retêm adequadamente os dados e que 33 (91,67%) delas não descartam os dados com segurança.

Diante disso, será sugerida proposta de encaminhamento às organizações nessa situação para que definam limites máximos e mínimos para a retenção dos dados, assegurando que a retenção e o descarte sejam realizados em conformidade ao processo de gestão de dados.

Criptografia dos dispositivos

A criptografia de dados em dispositivos de usuário final, protege informações armazenadas em laptops, desktops, tablets e outros dispositivos usados para acessar ou processar dados sensíveis. A criptografia transforma os dados em uma forma ilegível para terceiros, garantindo sua confidencialidade mesmo em caso de perda ou roubo do dispositivo.

Nesse contexto, a medida de segurança 3.6 dos Controles CIS v8 apresenta a necessidade de a organização criptografar os dados em dispositivos de usuários finais que contenham dados sensíveis.

Considerando a prática apresentada, a Equipe de Auditoria analisou as respostas do item 0303 do questionário submetido pelo TSID02 e os comentários do gestor, para averiguar se as organizações criptografam os dados dos dispositivos de usuários finais.

Da análise das respostas, conforme ilustrado na Figura 12, verificou-se que 32 (88,9%) das 36 organizações auditadas não adotam a prática.

Diante disso, será sugerida proposta de encaminhamento às organizações nessa situação para que criptografem os dados nos dispositivos de usuário final que contenham dados sensíveis.

Conclusão

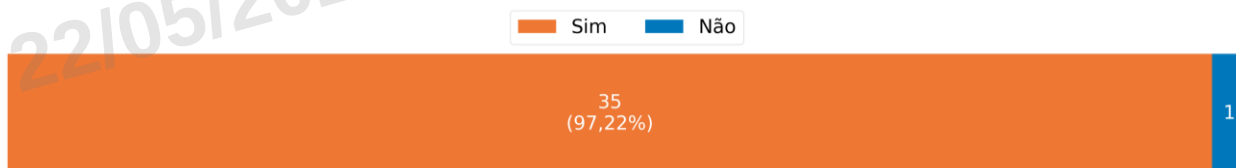
Os procedimentos executados nesta seção foram desenvolvidos para responder à questão de auditoria nº 3, qual seja:

Q3. As organizações adotam as medidas básicas de higiene cibernética para a proteção de seus dados conforme disposto no Controle 3 dos Controles CIS v8?

Com base nas situações avaliadas, verificou-se, como pode ser visto na

Figura 13, que 35 (97,2%) das 36 organizações auditadas não adotam adequadamente as medidas básicas de segurança cibernética dispostas no Controle 3 dos Controles CIS versão 8.

Figura 13 – Quantitativo de organizações contidas no achado 3



(Fonte: elaboração própria)

Diante disso, serão sugeridas propostas de encaminhamento às organizações para que protejam adequadamente seus dados aos moldes da ISO/IEC 27002:2022 e das medidas de segurança básicas dos Controles CIS v8.

4.2.3.4 Causas

- Não investigadas.

4.2.3.5 Efeitos

- Omissão de práticas e controles essenciais na garantia da proteção dos dados da organização impactando a confidencialidade, integridade e disponibilidade dos dados da organização;
- Falhas na identificação dos dados geridos e processados pela organização, inclusive os dados sensíveis;
- Acesso indevido a dados por pessoa sem a permissão necessária;
- Desconformidade com requisitos regulatórios, legais e contratuais;
- Violação na confidencialidade e integridade dos dados.

4.2.3.6 Propostas de Encaminhamento

Ressalta-se que as propostas de encaminhamento individualizadas para cada organização auditada constam no bojo dos relatórios individuais presentes nos conjuntos de anexos AN08 a AN43. Dessa forma, seguem as sugestões gerais propostas pela Equipe de Auditoria:

- **Comunicação com Recomendação** às organizações que não possuem processo adequado de gestão de dados para que adotem integralmente a medida de segurança 3.1 (Estabelecer e manter um processo de gestão de dados) prevista nos Controles CIS v8, atentando-se, minimamente, em estabelecer,

manter e revisar periodicamente um processo de gestão de dados que trate a sensibilidade dos dados, o proprietário dos dados, o tratamento dos dados, os limites de retenção de dados e os requisitos de descarte, conforme as políticas definidas pela organização;

- **Comunicação com Recomendação** às organizações que não possuem inventário de dados adequado para que adotem integralmente a medida de segurança 3.2 (Estabelecer e manter um inventário de dados) prevista nos Controles CIS v8, atentando-se, minimamente, em estabelecer, manter e revisar periodicamente um inventário de dados sensíveis, com base no processo de gestão de dados da organização;
- **Comunicação com Recomendação** às organizações que não configuram adequadamente as listas de controle de acesso a dados para que adotem integralmente a medida de segurança 3.3 (Configurar listas de controle de acesso a dados) prevista nos Controles CIS v8, atentando-se, minimamente, em configurar listas de controle de acesso a dados com base na necessidade de conhecimento de cada usuário, aplicando-as para controlar o acesso a sistemas de arquivos, bancos de dados e sistemas locais e remotos;
- **Comunicação com Recomendação** às organizações que não retêm adequadamente seus dados para que adotem integralmente a medida de segurança 3.4 (Aplicar retenção de dados) prevista nos Controles CIS v8, atentando-se, minimamente, com a definição de limites máximos e mínimos para a retenção dos dados, assegurando que essa retenção seja realizada em conformidade com o processo de gestão de dados da organização;
- **Comunicação com Recomendação** às organizações que não descartam adequadamente seus dados para que adotem integralmente a medida de segurança 3.5 (Descartar dados com segurança) prevista nos Controles CIS v8, atentando-se, minimamente, em descartar os dados com segurança conforme descrito no processo de gestão de dados da organização, certificando-se que o processo e o método de descarte sejam adequados com a sensibilidade dos dados;
- **Comunicação com Recomendação** às organizações que não criptografam os dispositivos de usuários finais para que adote integralmente a medida de segurança 3.6 (Criptografar dados em dispositivos de usuário final) prevista nos

Controles CIS v8, atentando-se, minimamente, em criptografar os dados nos dispositivos de usuário final que contenham dados sensíveis;

4.2.4. Achado 4 – Medidas básicas de segurança cibernética insuficientes no estabelecimento de configuração segura dos ativos da organização

4.2.4.1. Critérios

- Lei Federal nº 12.527/2011 (LAI), art. 6º, incisos II e III;
- Lei Federal nº 13.709/2018 (LGPD), art. 6º, inciso VII, 46 e 47;
- Norma Técnica ABNT NBR ISO/IEC 27002:2022, item 8.9 (Gestão de configuração);
- Controles CIS versão 8, medidas de segurança 4.1 (Estabelecer e manter um processo de configuração segura), 4.2 (Estabelecer e Manter um Processo de Configuração Segura para a Infraestrutura de Rede), 4.3 (Configurar o bloqueio automático de sessão nos ativos corporativos), 4.4 (Implementar e gerenciar um firewall nos servidores), 4.5 (Implementar e gerenciar um firewall nos dispositivos de usuário final), 4.6 (Gerenciar com segurança os ativos e softwares corporativos) e 4.7 (Gerenciar contas padrão nos ativos e softwares corporativos);
- Instrução Normativa PRODERJ/PRE nº 02/2022, art. 9º, e Anexo Único, Item 8.1.

4.2.4.2. Evidências

As evidências que embasam este achado para todas as organizações estão no Anexo AN04.

4.2.4.3 Situação Encontrada

A configuração padrão de ativos e *softwares* corporativos frequentemente prioriza a facilidade de uso em detrimento da segurança. Essa abordagem cria vulnerabilidades, como o uso de contas com senhas padrão e a implementação de protocolos inadequados, que podem comprometer a proteção das informações institucionais.

Para mitigar esses riscos, a adoção de práticas de configuração segura é essencial, assegurando que ativos e softwares sejam configurados corretamente desde o início e que essa segurança seja mantida ao longo do tempo.

A configuração segura configura-se como mais uma prática que quando adotada em conjunto com as demais medidas de segurança avaliadas asseguram minimamente as exigências dispostas no art. 6º, incisos II e III, da Lei de Acesso à Informação (LAI) e nos artigos 46 e 47 da Lei Geral de Proteção de Dados Pessoais (LGPD).

Para o âmbito estadual, destaca-se o art. 9º da Instrução Normativa PRODERJ/PRE nº 02/2022, aplicável ao Poder Executivo, que conjuntamente com o item 8.1 do seu Anexo Único, exigem que as organizações realizem procedimentos padronizados de configuração e de adequação às melhores práticas de segurança (*hardening*).

Essas exigências podem ser asseguradas, no contexto da configuração segura, adotando-se as orientações do item²⁴ 8.9 da Norma Técnica ISO/IEC 27002:2022 e as ações das medidas básicas²⁵ de segurança cibernética 4.1, 4.2, 4.3, 4.4, 4.5, 4.6 e 4.7 dos Controles CIS versão 8.

Nesse sentido, as medidas básicas (de higiene cibernética) do Controles 04 dos Controles CIS versão 8 representam um conjunto mínimo de práticas necessárias para preservar a confidencialidade, integridade e disponibilidade das informações sob responsabilidade da Administração, além de atender aos dispositivos legais mencionados.

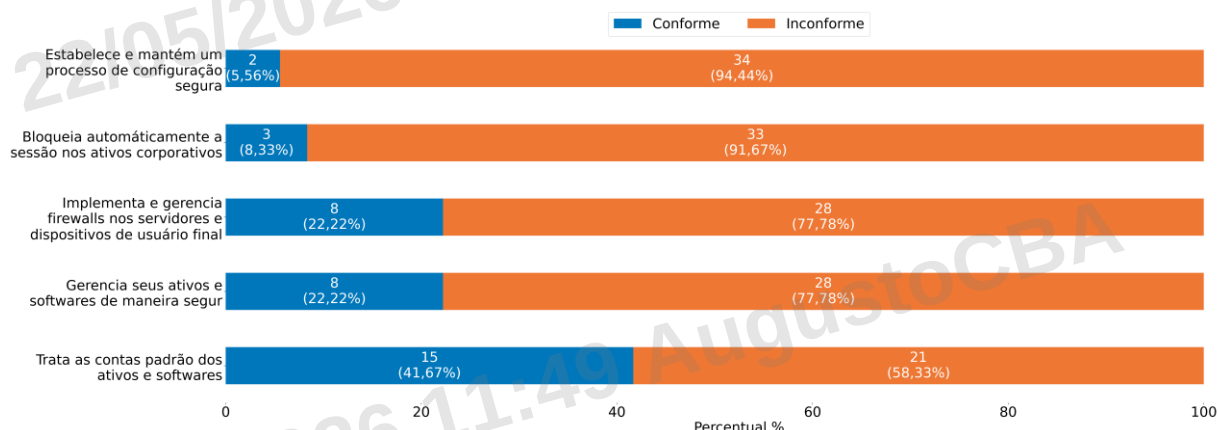
Para executar uma configuração segura adequada dos *softwares* e inventários corporativos a organização deve, no mínimo, (1) estabelecer e manter processo de configuração segura, (2) configurar o bloqueio automático de sessão nos ativos corporativos, (3) implementar e gerenciar *firewalls* nos servidores e dispositivos de usuário final, (4) gerenciar de forma segura os ativos e *softwares* corporativos e (5) gerenciar as contas padrão nos ativos e *softwares* corporativos.

Assim, com base na análise dos itens 0401, 0402, 0403, 0404 e 0405 do Questionário submetido pelo TSID02, a Equipe de Auditoria identificou o seguinte panorama (Figura 14):

²⁴ O item 8.9 da ISO/IEC 27002:2022 dispõe que as configurações, incluindo as de segurança, de hardware, softwares, serviços e redes sejam estabelecidas, documentadas, implementadas, monitoradas e analisadas criticamente. Para isso a organização deve definir e implementar processos e ferramentas para impor as configurações definidas ao longo da vida útil dos softwares e ativos.

²⁵ As medidas básicas do Controle 04 (Configuração segura de ativos corporativos e software) dos Controles CIS versão 8 representam o conjunto mínimo de medidas para estabelecer e manter uma configuração segura de ativos corporativos e software nas organizações.

Figura 14 – Distribuição das práticas de configuração segura



(Fonte: elaboração própria)

Essas situações ensejaram o presente achado e serão detalhadas nas seções subsequentes.

Processo de configuração segura

Como já apresentado, a organização deve estabelecer um processo robusto de configuração segura (*hardening*) para fortalecer a proteção de *softwares* e ativos corporativos, reduzindo vulnerabilidades relacionadas a configurações inadequadas ou padrões inseguros. Sua ausência expõe a organização a riscos de exploração de configurações padrão ou inseguras nos ativos corporativos.

Nessa feita, as medidas de segurança 4.1 e 4.2 dos Controles CIS versão 8 apresentam diretrizes do escopo do processo de configuração segura.

Considerando as práticas apresentadas, a Equipe de Auditoria analisou as respostas do item 0401 do questionário submetido pelo TSID02 e os comentários do gestor, para averiguar a adoção do processo de configuração segura.

Da análise das respostas, conforme ilustrado na Figura 14, verificou-se que 34 (94,4%) das 36 organizações auditadas não adotam essa prática.

Diante disso, será sugerida proposta de encaminhamento às organizações nessa situação para que estabeleçam, mantenham e revisem periodicamente um processo de configuração segura que contenha os *softwares* e ativos corporativos.

Bloqueio automático de sessão

A ausência de um bloqueio automático de sessão em ativos corporativos expõe a organização ao risco de perda de confidencialidade, possibilitando que terceiros não autorizados acessem informações as quais não tenham permissão ou necessidade de acessar.

A medida de segurança 4.3 dos Controles CIS versão 8 apresenta diretrizes básicas para implementar o bloqueio automático de sessão, abrangendo tanto sistemas operacionais quanto dispositivos móveis. Essas diretrizes estabelecem padrões de períodos de inatividade que ajudam a mitigar o risco de acessos não autorizados.

Considerando as práticas apresentadas, a Equipe de Auditoria analisou as respostas do item 0402 do questionário submetido pelo TSID02 e os comentários do gestor, para averiguar se a organização configura o bloqueio automático das sessões dos ativos corporativos.

Da análise das respostas, conforme ilustrado na Figura 14, verificou-se que 33 (94,44%) das 36 organizações auditadas não adotam essa prática.

Diante disso, será sugerida proposta de encaminhamento às organizações nessa situação para que configurem nos ativos corporativos o bloqueio automático de sessão após um período de inatividade.

Gestão de *firewalls*

A utilização adequada de *firewalls* em servidores e dispositivos de usuário final é essencial para proteger a infraestrutura de TI contra acessos não autorizados, ataques cibernéticos e atividades maliciosas.

A ausência ou configuração inadequada desses dispositivos aumenta significativamente a superfície de ataque, expondo serviços e portas desprotegidas ao ambiente externo e elevando a probabilidade de invasões.

As medidas de segurança 4.4 e 4.5 dos Controles CIS versão 8, oferecem orientações claras para o gerenciamento eficaz de *firewalls*.

Considerando as práticas apresentadas, a Equipe de Auditoria analisou as respostas do item 0403 do questionário submetido pelo TSID02 e os comentários do gestor, para averiguar se a organização gerencia adequadamente a utilização de *firewalls*.

Da análise das respostas, conforme ilustrado na Figura 14, verificou-se que 28 (77,78%) das 36 organizações auditadas não adotam essa prática.

Diante disso, será sugerida proposta de encaminhamento às organizações nessa situação para que implementem e gerenciem *firewalls* nos servidores e nos dispositivos de usuários finais.

Gestão de ativos de forma segura

O gerenciamento de ativos corporativos com protocolos seguros é uma prática crucial para assegurar a confidencialidade e a integridade das transações entre usuários e ativos. O uso de protocolos inseguros pode expor dados sensíveis e comprometer a comunicação entre sistemas e dispositivos.

A medida de segurança 4.6 dos Controles CIS versão 8 apresenta exemplos de protocolos recomendados e aqueles que devem ser evitados pelas organizações, destacando a importância de adotar práticas seguras no gerenciamento de ativos.

Considerando a prática apresentada, a Equipe de Auditoria analisou as respostas do item 0404 do questionário submetido pelo TSID02 e os comentários do gestor, para averiguar se a organização gerencia de forma segura seus *softwares* e ativos corporativos.

Da análise das respostas, conforme ilustrado na Figura 14, verificou-se que 28 (77,78%) das 36 organizações auditadas não adotam essa prática.

Diante disso, será sugerida proposta de encaminhamento às organizações nessa situação para que gerenciem de forma segura os *softwares* e ativos corporativos.

Tratamento de contas padrão (*default*) nos ativos e *softwares*

O tratamento de contas padrão mitiga riscos associados a credenciais genéricas, pré-configuradas ou públicas, amplamente conhecidas por atacantes. Contas padrão frequentemente possuem privilégios administrativos e, quando não são gerenciadas, representam vulnerabilidades significativas para a organização.

A medida de segurança 4.7 dos Controles CIS versão 8 fornece orientações sobre a necessidade de se gerenciar as contas padrão, e apresenta possíveis hipóteses de tratamento.

Considerando as práticas apresentadas, a Equipe de Auditoria analisou as respostas do item 0405 do questionário submetido pelo TSID02 e os comentários do gestor, para averiguar se a organização trata as contas padrão de seus ativos corporativos.

Da análise das respostas, conforme ilustrado na Figura 14, verificou-se que 21 (58,33%) das 36 organizações auditadas não adotam essa prática.

Diante disso, será sugerida proposta de encaminhamento às organizações nessa situação para que gerenciem as contas padrão de administrador e as pré-configuradas pelos fabricantes dos softwares e ativos corporativos.

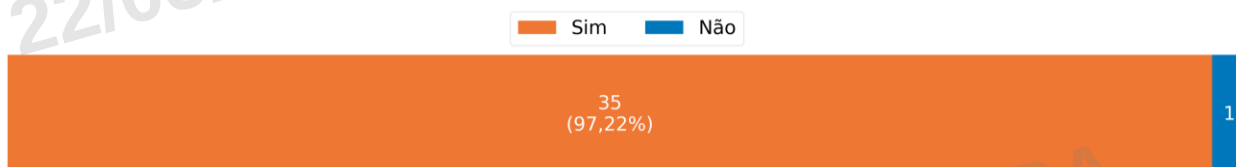
Conclusão

Os procedimentos executados nesta seção foram desenvolvidos para responder à questão de auditoria nº 4, qual seja:

Q4. As organizações adotam as medidas básicas de higiene cibernética para estabelecer e manter a configuração segura de seus ativos e *softwares* conforme disposto no Controle 4 dos Controles CIS v8?

Com base nas situações avaliadas, verificou-se, como pode ser visto na Figura 15, que 35 (97,2%) das 36 organizações auditadas não adotam adequadamente as medidas básicas de segurança cibernética dispostas no Controle 4 dos Controles CIS versão 8.

Figura 15 – Quantitativo de organizações contidas no achado 4



(Fonte: elaboração própria)

Diante disso, serão sugeridas propostas de encaminhamento às organizações para que configurem de forma adequadamente segura seus *softwares* e ativos corporativos aos moldes da ISO/IEC 27002:2022 e das medidas de segurança básicas dos Controles CIS v8.

4.2.4.4 Causas

- Não investigadas.

4.2.4.5 Efeitos

- Utilização de configuração padrão vulnerável impactando a capacidade de proteção dos ativos, dos softwares e da infraestrutura de rede utilizada na organização;
- Ativo corporativo com sessão de acesso com tempo indefinido, podendo resultar em utilização da sessão por terceiros não autorizados;
- Existência de servidor ou dispositivo de usuário final sem proteção de um firewall ou com configuração não segura;
- Perda de confidencialidade e integridade das comunicações;
- Existência de contas padrão inseguras, podendo resultar em acesso não autorizado por terceiros.

4.2.4.6 Propostas de Encaminhamento

Ressalta-se que as propostas de encaminhamento individualizadas para cada organização auditada constam no bojo dos relatórios individuais presentes nos conjuntos de anexos AN08 a AN43. Dessa forma, seguem as sugestões gerais propostas pela Equipe de Auditoria:

- **Comunicação com Recomendação** às organizações que não possuem processo de configuração segura adequado para que adotem integralmente as medidas de segurança 4.1 (Estabelecer e manter um processo de configuração segura) e 4.2 (Estabelecer e Manter um Processo de Configuração Segura para a Infraestrutura de Rede) previstas nos Controles CIS v8, atentando-se, minimamente, em estabelecer, manter e revisar periodicamente um processo de configuração segura para ativos corporativos, softwares e dispositivos de rede da organização;
- **Comunicação com Recomendação** às organizações que não configuram adequadamente o bloqueio automático de sessão em seus ativos para que adotem integralmente a medida de segurança 4.3 (Configurar o bloqueio automático de sessão nos ativos corporativos) prevista nos Controles CIS v8, atentando-se, minimamente, em configurar nos ativos corporativos o bloqueio automático de sessão após um período de inatividade que, para os sistemas

operacionais, não deve exceder 15 minutos e, para os dispositivos móveis, não deve exceder 2 minutos;

- **Comunicação com Recomendação** às organizações que não gerenciam adequadamente os *firewalls* em seus ativos para que adotem integralmente as medidas de segurança 4.4 (Implementar e gerenciar um *firewall* nos servidores) e 4.5 (Implementar e gerenciar um *firewall* nos dispositivos de usuário final) previstas nos Controles CIS v8, atentando-se, minimamente, em implementar e gerenciar *firewalls* nos servidores e nos dispositivos de usuários finais;
- **Comunicação com Recomendação** às organizações que não gerenciam segura e adequadamente os ativos para que adotem integralmente a medida de segurança 4.6 (Gerenciar com segurança os ativos e *software* corporativos) prevista nos Controles CIS v8, atentando-se, minimamente, em gerenciar seguramente os ativos corporativos e *softwares* da organização por meio da utilização de protocolos seguros;
- **Comunicação com Recomendação** às organizações que não tratam as contas padrão dos ativos para que adotem integralmente a medida de segurança 4.7 (Gerenciar contas padrão nos ativos e *softwares* corporativos) prevista nos Controles CIS v8, atentando-se, minimamente, em gerenciar as contas padrão de administrador e as pré-configuradas pelos fabricantes dos ativos e *softwares* corporativos da organização;

4.2.5. Achado 5 – Medidas básicas de segurança cibernética insuficientes na gestão de contas e de controle de acesso

4.2.5.1. Critérios

- Lei Federal nº 12.527/2011 (LAI), art. 6º, incisos II e III;
- Lei Federal nº 13.709/2018 (LGPD), art. 6º, inciso VII, 46 e 47;
- Norma Técnica ABNT NBR ISO/IEC 27002:2022, item 5.15 (Controle de acesso) e 5.16 (Gestão de identidade);
- Controles CIS versão 8, medidas de segurança 5.1 (Estabelecer e manter um inventário de contas), 5.2 (Usar senhas exclusivas), 5.3 (Desabilitar contas inativas), 5.4 (Restringir privilégios de administrador a contas de Administrador dedicadas), 6.1 (Estabelecer um Processo de Concessão de Acesso), 6.2

(Estabelecer um Processo de Revogação de Acesso), 6.3 (Exigir MFA para aplicações expostas externamente), 6.4 (Exigir MFA para acesso remoto à rede) e 6.5 (Exigir MFA para acesso administrativo);

- Instrução Normativa PRODERJ/PRE nº 02/2022, art. 9º, e Anexo Único, Item 8.3;
- Resolução TJ/OE nº 28/2022, art. 22, inciso III;
- Resolução CNMP nº 294/2024, art. 23, §3º, incisos I, II, III e IV;

4.2.5.2. Evidências

As evidências que embasam este achado para todas as organizações estão no Anexo AN04.

4.2.5.3 Situação Encontrada

A gestão eficaz de contas é essencial para evitar que invasores, internos ou externos, obtenham acesso indevido aos sistemas e dados da organização. Credenciais de contas mal gerenciadas, senhas fracas, contas inativas ou compartilhadas, representam pontos de vulnerabilidade críticos.

Enquanto a gestão do controle de acesso desempenha papel central para garantir que os usuários tenham acesso apenas aos dados e sistemas necessários para realizar suas funções, minimizando o risco de exposição indevida, contas com privilégios excessivos ou mal gerenciadas podem representar uma vulnerabilidade significativa, especialmente em caso de ataques.

Assim, configuram-se como práticas essenciais que, quando adotadas em conjunto com as demais medidas de segurança apresentadas, asseguram minimamente as exigências dispostas no art. 6º, incisos II e III, da Lei de Acesso à Informação (LAI) e nos artigos 46 e 47 da Lei Geral de Proteção de Dados Pessoais (LGPD).

Esses requisitos podem ser assegurados, no contexto da gestão de contas e de controle de acesso, adotando-se as orientações dos itens²⁶ 5.15 e 5.16 da Norma Técnica

²⁶ Os itens 5.15, 5.16 e 5.17 da ISO/IEC 27002:2022 recomendam que o ciclo de vida das identidades seja gerenciado a fim de permitir a identificação individualizada de indivíduos e sistemas e permitir a cessação devida de direitos de acesso. Orienta que regras para controlar os acessos às informações sejam estabelecidas e implementadas com base nos requisitos de segurança da informação.

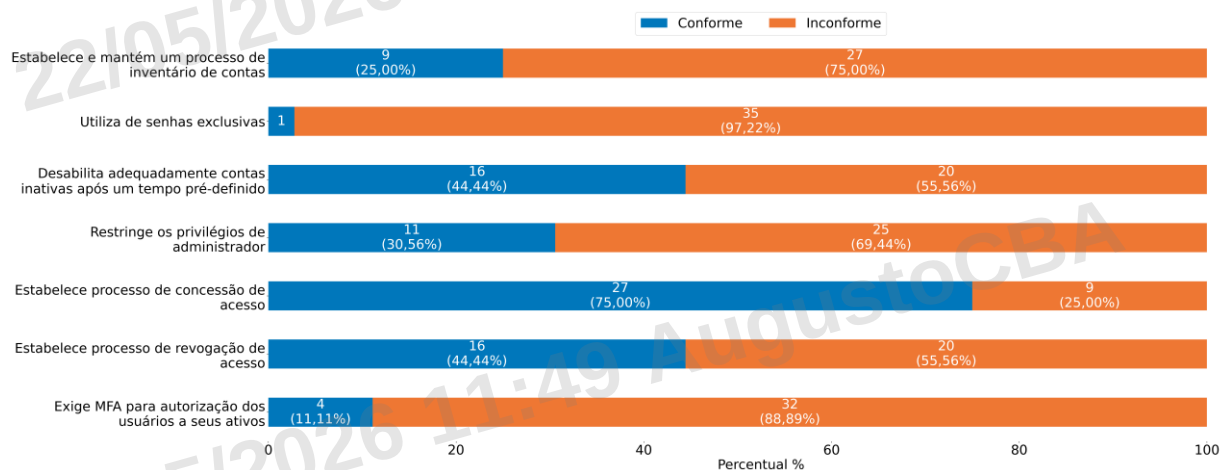
ISO/IEC 27002:2022 e as medidas básicas²⁷ de segurança cibernética 5.1, 5.2, 5.3, 5.4, 6.1, 6.2, 6.3, 6.4 e 6.5 dos Controles CIS versão 8.

Nesse sentido, implementar as medidas básicas (de higiene cibernética) dos Controles 05 e 06 dos Controles CIS versão 8 representam um conjunto mínimo de práticas necessárias para preservar a confidencialidade, integridade e disponibilidade das informações sob responsabilidade da Administração, além de atender aos dispositivos legais mencionados.

Para executar uma gestão de contas e de controle de acesso, a organização deve, no mínimo, (1) estabelecer e manter um inventário de contas, (2) assegurar o uso de senhas exclusivas, (3) desabilitar contas inativas, (4) restringir privilégios de administrador a contas exclusivas para o perfil, (5) estabelecer um processo de concessão e revogação de acesso, e (6) exigir a utilização de MFA no acesso a contas administrativas, sistemas e rede.

Assim, com base na análise dos itens 0501, 0502, 0503, 0504, 0601, 0602 e 0603 do Questionário submetido pelo TSID02, a Equipe de Auditoria identificou o seguinte panorama (Figura 16):

Figura 16 – Distribuição das práticas de gestão de contas e de controle de acesso



(Fonte: elaboração própria)

Essas situações ensejaram o presente achado e serão detalhadas nas seções subsequentes.

²⁷ As medidas básicas do Controle 05 (Gestão de contas) e Controle 06 (Gestão do controle de acesso) dos Controles CIS versão 8 representam o conjunto mínimo de medidas para atribuir e gerenciar autorização de credenciais para contas de usuário, bem como criar, atribuir, gerenciar e revogar credenciais de acesso e privilégios de contas.

Inventário de contas

O inventário de contas é uma prática essencial para o controle e gestão centralizada de todas as contas de usuário, administrador e serviço em uma organização. Essa prática assegura visibilidade e rastreabilidade, reduzindo os riscos de acessos não autorizados, abusos de privilégios e violações de dados.

A ausência de um inventário expõe a organização ao risco de manter contas inativas ou desnecessárias, que podem ser exploradas por atacantes.

Nesse contexto, a medida de segurança 5.1 dos Controles CIS versão 8 apresenta diretrizes e ações específicas sobre como estabelecer e manter um inventário de contas.

Considerando a prática apresentada, a Equipe de Auditoria analisou as respostas do item 0501 do questionário submetido pelo TSID02 e os comentários do gestor, para averiguar se a organização estabelece e mantém um inventário de contas adequado.

Da análise das respostas, conforme ilustrado na Figura 16, verificou-se que 27 (75%) das 36 organizações auditadas não adotam essa prática.

Diante disso, será sugerida proposta de encaminhamento às organizações nessa situação para que estabeleçam e mantenham um inventário de contas.

Senhas exclusivas

Por senhas exclusivas, entendem-se as senhas que são unicamente criadas e usadas por um único usuário ou sistema e não são compartilhadas ou reutilizadas entre contas, dispositivos ou aplicações diferentes.

Sua adoção minimiza os impactos de eventuais comprometimentos de senhas. Senhas exclusivas asseguram que, mesmo descobertas ou vazadas, o acesso indevido a outras contas ou sistemas seja impedido.

Nesse contexto, a medida de segurança 5.2 dos Controles CIS versão 8 apresenta diretrizes a serem seguidas para utilizar senhas exclusivas nos ativos corporativos.

Considerando a prática apresentada, a Equipe de Auditoria analisou as respostas do item 0502 do questionário submetido pelo TSID02 e os comentários do gestor, para averiguar se as organizações asseguram a adoção dessa prática.

Da análise das respostas, conforme ilustrado na Figura 16, verificou-se que 35 (97,2%) das 36 organizações auditadas não a adotam.

Diante disso, será sugerida proposta de encaminhamento às organizações nessa situação para que utilizem senhas exclusivas para acesso aos seus sistemas e ativos corporativos.

Desabilitar contas inativas

Contas inativas frequentemente passam despercebidas, tornando-se alvos fáceis para atacantes que desejam explorar sistemas sem serem detectados. Dessa forma, seu tratamento reduz o risco de acessos não autorizados e previne o uso indevido de credenciais que não estão mais sendo utilizadas.

A medida de segurança 5.3 dos Controles CIS versão 8 orienta as organizações a desabilitarem ou excluïrem as contas inativas após um período de 45 dias de inatividade.

Considerando a prática apresentada, a Equipe de Auditoria analisou as respostas do item 0503 do questionário submetido pelo TSID02 e os comentários do gestor, para averiguar se as organizações asseguram a adoção dessa prática.

Da análise das respostas, conforme ilustrado na Figura 16, verificou-se que 20 (55,56%) das 36 organizações auditadas não a adotam.

Diante disso, será sugerida proposta de encaminhamento às organizações nessa situação para que tratem as contas inativas presentes em seu inventário após um período de 45 dias de inatividade.

Contas de administrador restritas a atividades administrativas

É imperioso que as contas de administrador sejam utilizadas exclusivamente para funções de administração. Essa prática evita que contas de usuários comuns acumulem privilégios elevados e garante um controle rigoroso sobre ações críticas realizadas nos sistemas e ativos corporativos.

A ausência de contas dedicadas para privilégios administrativos pode expor a organização ao comprometimento de contas administrativas, o que aumenta o impacto lesivo do vazamento pelas possibilidades de acesso do usuário, facilitando movimentos laterais dos invasores.

A medida de segurança 5.4 dos Controles CIS versão 8 orienta as organizações a restringirem o privilégio de administrador apenas para as contas dedicadas a essa

função, evitando os privilégios a usuários comuns. Ressalta também que as contas de administrador não devem ser utilizadas para atividades comuns de usuário.

Considerando a prática apresentada, a Equipe de Auditoria analisou as respostas do item 0504 do questionário submetido pelo TSID02 e os comentários do gestor, para averiguar se as organizações asseguram a adoção dessa prática.

Da análise das respostas, conforme ilustrado na Figura 16, verificou-se que 25 (69,44%) das 36 organizações auditadas não a adotam.

Diante disso, será sugerida proposta de encaminhamento às organizações nessa situação para que restrinjam os privilégios de administrador apenas para as contas dedicadas a essa função, considerando que elas não devem ser utilizadas para atividades comuns do usuário.

Concessão e revogação de acesso

Os processos de concessão e revogação de acessos são pilares fundamentais para proteger sistemas e dados sensíveis, garantindo que somente pessoas autorizadas tenham acesso aos recursos necessários no momento certo. Ignorar essas medidas expõe a organização a riscos de segurança, não conformidade e prejuízos operacionais.

As medidas de segurança 6.1 e 6.2 dos Controles CIS versão 8 orientam as organizações a estabelecerem um processo automatizado de concessão e revogação de acesso.

Considerando a prática apresentada, a Equipe de Auditoria analisou as respostas dos itens 0601 e 0602 do questionário submetido pelo TSID02 e os comentários do gestor, para averiguar se as organizações asseguram a adoção dessa prática.

Da análise das respostas, conforme ilustrado na Figura 16, verificou-se que 9 (25%) das 36 organizações auditadas não estabeleceram um processo adequado de concessão de acesso e que 20 (55,56%) não estabeleceram um processo adequado de revogação de acesso.

Diante disso, será sugerida proposta de encaminhamento às organizações nessas situações para que estabeleçam e mantenham um processo automatizado para concessão e revogação de acesso.

Autenticação multifator (MFA)

Por autenticação multifator - MFA, entende-se a camada adicional de segurança que exige que o usuário forneça pelo menos dois fatores de autenticação de diferentes categorias (algo que sabe, como uma senha; algo que possui, como um *token* ou dispositivo móvel; ou algo que é, como uma biometria) para acessar um recurso da organização.

A implementação de MFA para aplicações expostas externamente, acessos remotos à rede e acessos administrativos reforça a segurança em pontos críticos, minimiza riscos e demonstra alinhamento às melhores práticas e regulamentações de segurança cibernética.

As medidas de segurança 6.3, 6.4 e 6.5 dos Controles CIS versão 8 orientam as organizações a exigirem a utilização de MFA para obtenção de acesso administrativo, à rede e aos sistemas.

Considerando a prática apresentada, a Equipe de Auditoria analisou as respostas do item 0603 do questionário submetido pelo TSID02 e os comentários do gestor, para averiguar se as organizações asseguram a adoção dessa prática.

Da análise das respostas, conforme ilustrado na Figura 16, verificou-se que 32 (88,89%) das 36 organizações auditadas não exigem MFA para obter acesso administrativo, a rede e aos sistemas.

Diante disso, será sugerida proposta de encaminhamento às organizações nessas situações para que exijam a utilização de MFA quando do acesso administrativo, à rede e aos sistemas expostos externamente.

Conclusão

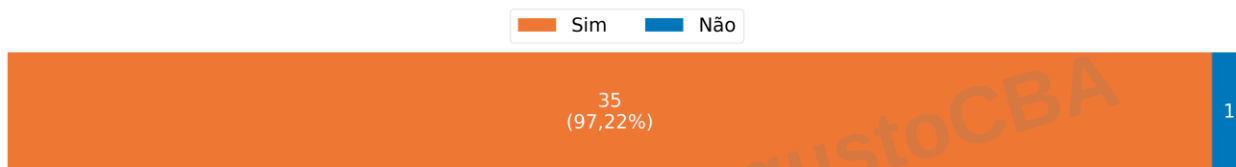
Os procedimentos executados nesta seção foram desenvolvidos para responder à questão de auditoria nº 5, qual seja:

Q5. As organizações adotam as medidas básicas de higiene cibernética para atribuir e gerenciar a autorização de credenciais para contas de usuários, bem como para criar, alterar e revogar credenciais e privilégios de acesso dessas contas, conforme disposto nos Controles 5 e 6 dos Controles CIS v8?

Com base nas situações avaliadas, verificou-se, como pode ser visto na Figura 17, que 35 (97,2%) das 36 organizações auditadas não adotam adequadamente as

medidas básicas de segurança cibernética dispostas nos Controle 05 e 06 dos Controles CIS versão 8.

Figura 17 – Quantitativo de organizações contidas no achado 5



(Fonte: elaboração própria)

Diante disso, serão sugeridas propostas de encaminhamento às organizações para que configurem de forma adequadamente segura seus *softwares* e ativos corporativos aos moldes da ABNT NBR ISO/IEC 27002:2022 e das medidas de segurança básicas dos Controles CIS v8.

4.2.5.4 Causas

- Não investigadas.

4.2.5.5 Efeitos

- Existência de contas inativas com direito de acesso aos ativos e dados da organização;
- Uso de privilégios de administrador por contas sem tal perfil impactando a segurança cibernética da organização por um aumento de risco de acesso não autorizado aos seus ativos ou aos seus dados;
- Uso de uma senha comum por um mesmo usuário para acesso a diferentes ativos;
- Existência de contas inativas com direito de acesso aos ativos e dados da organização;

4.2.5.6 Propostas de Encaminhamento

Ressalta-se que as propostas de encaminhamento individualizadas para cada organização auditada constam no bojo dos relatórios individuais presentes nos conjuntos de anexos AN08 a AN43. Dessa forma, seguem as sugestões gerais propostas pela Equipe de Auditoria:

- **Comunicação com Recomendação** às organizações que não possuam um inventário de contas adequado para que adotem integralmente a medida de segurança 5.1

(Estabelecer e manter um inventário de contas) prevista nos Controles CIS v8, atentando-se, minimamente, em estabelecer, manter e revisar periodicamente um inventário preciso, detalhado e atualizado de todas as contas gerenciadas na organização;

- **Comunicação com Recomendação** às organizações que não usam senhas exclusivas para acesso aos seus sistemas e ativos corporativos para que adotem integralmente a medida de segurança 5.2 (Usar senhas exclusivas) prevista nos Controles CIS v8, atentando-se, minimamente, em assegurar o uso de senhas exclusivas para todos os ativos corporativos, garantindo um tamanho mínimo de 8 caracteres às contas que usem MFA e 14 caracteres às contas que não o utilizem;
- **Comunicação com Recomendação** às organizações que não tratam as contas inativas para que adotem integralmente a medida de segurança 5.3 (Desabilitar contas inativas) prevista nos Controles CIS v8, atentando-se, minimamente, em excluir ou desabilitar as contas inativas após um período de 45 dias de inatividade;
- **Comunicação com Recomendação** às organizações que não limitam os privilégios de administrador apenas às contas dedicadas a essa função para que adotem integralmente a medida de segurança 5.4 (Restringir privilégios de administrador a contas de Administrador dedicadas) prevista nos Controles CIS v8, atentando-se, minimamente, em assegurar que as contas com privilégio de administrador sejam utilizadas estritamente para atividades administrativas;
- **Comunicação com Recomendação** às organizações que não estabeleceram um processo adequado de concessão de acesso para que adotem integralmente a medida de segurança 6.1 (Estabelecer um Processo de Concessão de Acesso) prevista nos Controles CIS v8, atentando-se, minimamente, em estabelecer um processo, preferencialmente automatizado, para concessão de acesso aos ativos corporativos nos casos de nova contratação, concessão de direitos ou mudança de função;
- **Comunicação com Recomendação** às organizações que não estabeleceram um processo adequado de revogação de acesso para que adotem integralmente a medida de segurança 6.2 (Estabelecer um Processo de Revogação de Acesso) prevista nos Controles CIS v8, atentando-se, minimamente, em estabelecer um processo, preferencialmente automatizado, para a concessão de acesso aos ativos corporativos em casos de nova contratação, concessão de direitos ou mudança de função;
- **Comunicação com Recomendação** às organizações que não exigem MFA para acesso a seu ambiente organizacional para que adotem integralmente as medidas de segurança 6.3 (Exigir MFA para aplicações expostas externamente), 6.4 (Exigir MFA para acesso remoto à rede) e 6.5 (Exigir MFA para acesso administrativo) previstas nos Controles CIS v8, atentando-se, minimamente, em exigir, onde houve suporte, a utilização de MFA para



acesso às aplicações corporativas expostas externamente, à rede e às contas de acesso administrativo;

5. COMENTÁRIOS DO GESTOR

Ao fim da análise dos dados, buscando fortalecer o caráter dialógico da fiscalização, foram encaminhados²⁸ relatórios individuais preliminares para cada organização, contendo seus achados de auditoria e as propostas de encaminhamento.

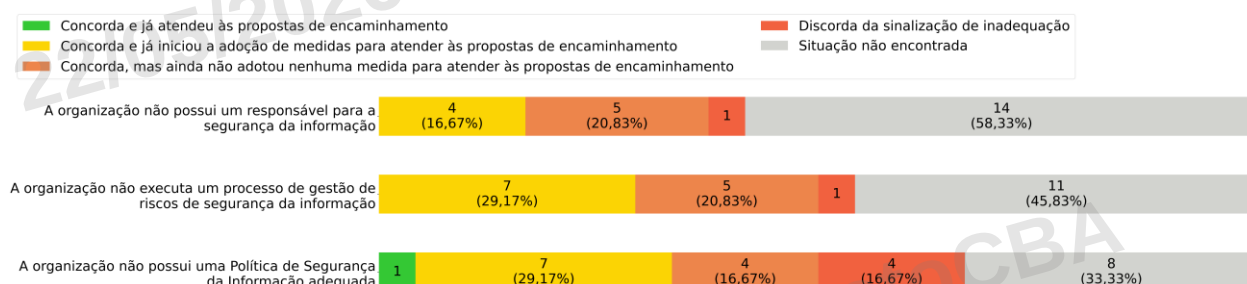
Essa etapa permitiu o esclarecimento de pontos obscuros, a correção de informações imprecisas ou inconsistentes e o aperfeiçoamento das medidas propostas.

Dessa forma, todas as respostas foram analisadas, resultando na alteração da situação encontrada das organizações que enviaram evidências corroborando suas manifestações.

5.1. Achado 1 – Ausência de uma estrutura básica atuante de segurança da informação que estabeleça papéis, políticas e responsabilidades

Como pode ser observado na Figura a seguir, em 6 (15,4%), do total de 39 comentários para as três situações encontradas, houve discordâncias. Também se verifica que 19 (46,1%) desses comentários declaram já ter iniciado a adoção de medidas para atender às propostas de encaminhamento sugeridas.

Figura 18 - Comentários do gestor sobre as situações encontradas para o Achado 1



(Fonte: elaboração própria)

Além disso, os comentários que discordaram da situação encontrada tiveram suas justificativas analisadas. Nesse sentido, a maior parte desses comentários trouxeram elementos suficientes para modificar a situação encontrada, como exibido na Tabela a seguir:

Tabela 2 - Quantidade de comentários de discordância que mantiveram ou modificaram a situação encontrada no Achado 1

	Manter situação encontrada	Modificar situação encontrada
A organização não possui um responsável para a segurança da informação	0	1

²⁸ Os relatórios individuais preliminares encontram-se presentes nos anexos individuais de cada auditado, AN08 a AN43.

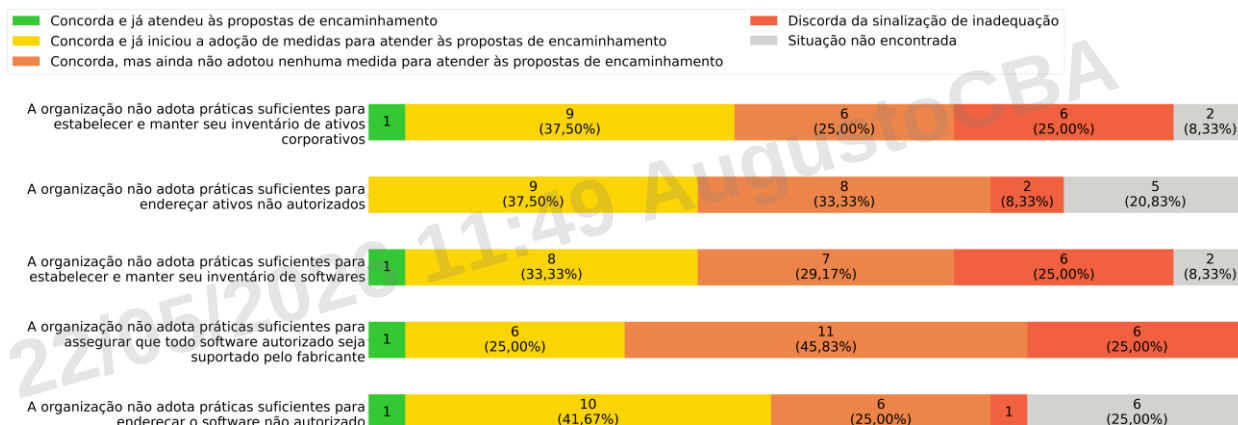
A organização não executa um processo de gestão de riscos de segurança da informação	1	0
A organização não possui uma Política de Segurança da Informação adequada	1	3

(Fonte: elaboração própria)

5.2. Achado 2 – Medidas básicas de segurança cibernética insuficientes na gestão ativa dos ativos corporativos e softwares

Como pode ser observado na Figura a seguir, em 21 (20%), do total de 105 comentários para as cinco situações encontradas, houve discordâncias. Também se verifica que 42 (40%) desses comentários declaram já ter iniciado a adoção de medidas para atender às propostas de encaminhamento sugeridas.

Figura 19 - Comentários do gestor sobre as situações encontradas para o Achado 2



(Fonte: elaboração própria)

Além disso, os comentários que discordaram da situação encontrada tiveram suas justificativas analisadas. Nesse sentido, a maior parte desses comentários foi suficiente para modificar a situação encontrada, como exibido na Tabela a seguir:

Tabela 3 - Quantidade de comentários de discordância que mantiveram ou modificaram a situação encontrada no Achado 2

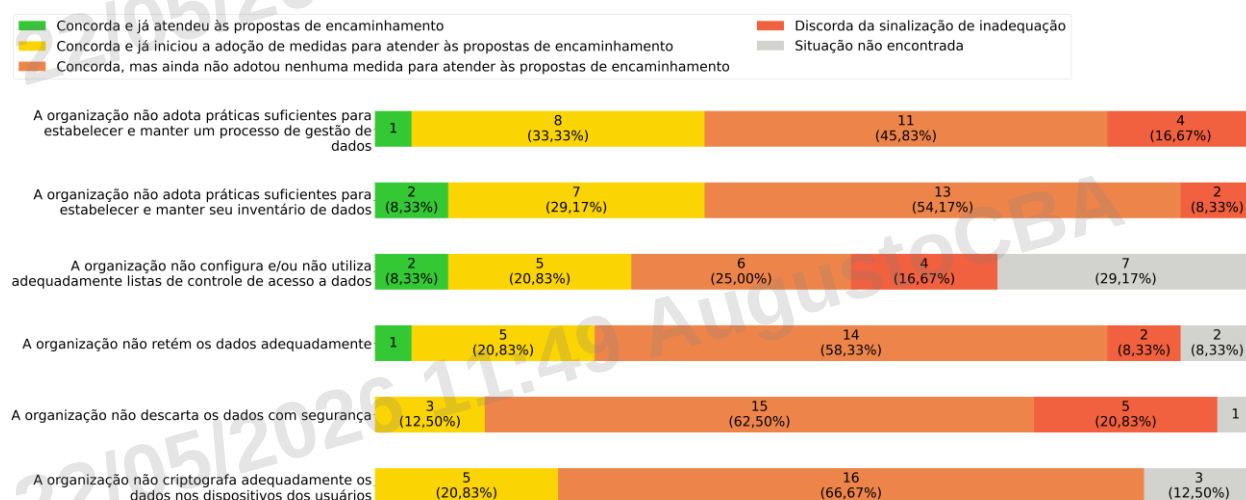
	Manter situação encontrada	Modificar situação encontrada
A organização não adota práticas suficientes para estabelecer e manter seu inventário de ativos corporativos	1	5
A organização não adota práticas suficientes para endereçar ativos não autorizados	0	2
A organização não adota práticas suficientes para estabelecer e manter seu inventário de softwares	2	4
A organização não adota práticas suficientes para assegurar que todo software autorizado seja suportado pelo fabricante	2	4
A organização não adota práticas suficientes para endereçar o software não autorizado	1	0

(Fonte: elaboração própria)

5.3. Achado 3 – Medidas básicas de segurança cibernética insuficientes na proteção dos dados da organização

Como pode ser observado na Figura a seguir, em 17 (12,9%), do total de 131 comentários para as seis situações encontradas, houve discordâncias. A única situação que não apresenta discordâncias nos comentários é que indica a ausência de “criptografia adequada dos dados nos dispositivos dos usuários”. Também se verifica que 75 (57,2%) desses comentários declaram a ausência de medidas para atender às propostas de encaminhamento.

Figura 20 - Comentários do gestor sobre as situações encontradas para o Achado 3



(Fonte: elaboração própria)

Além disso, os comentários que discordaram da situação encontrada tiveram suas justificativas analisadas. Nesse sentido, a maior parte desses comentários não trouxe elementos suficientes para modificar a situação encontrada, como exibido na Tabela a seguir:

Tabela 4 - Quantidade de comentários de discordância que mantiveram ou modificaram a situação encontrada no Achado 3

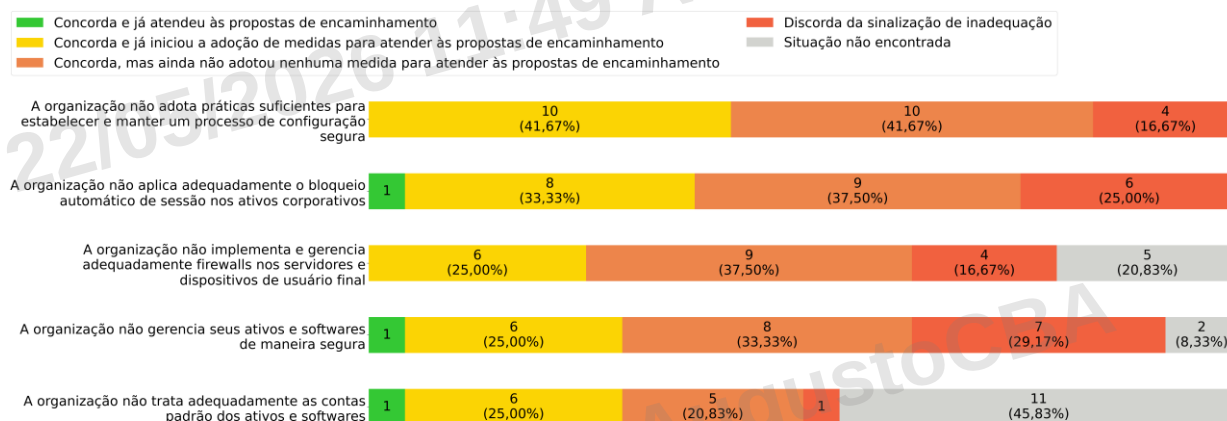
	Manter situação encontrada	Modificar situação encontrada
A organização não adota práticas suficientes para estabelecer e manter um processo de gestão de dados	0	4
A organização não adota práticas suficientes para estabelecer e manter seu inventário de dados	1	1
A organização não configura e/ou não utiliza adequadamente listas de controle de acesso a dados	2	2
A organização não retém os dados adequadamente	2	0
A organização não descarta os dados com segurança	4	1

(Fonte: elaboração própria)

5.4. Achado 4 – Medidas básicas de segurança cibernética insuficientes no estabelecimento de configuração segura dos ativos da organização

Como pode ser observado na Figura a seguir, em 22 (21,5%), do total de 102 comentários para as cinco situações encontradas, houve discordâncias. Também se verifica que 41 (40,2%) desses comentários declaram a ausência de medidas para atender às propostas de encaminhamento.

Figura 21 - Comentários do gestor sobre as situações encontradas para o Achado 4



(Fonte: elaboração própria)

Além disso, os comentários que discordaram da situação encontrada tiveram suas justificativas analisadas. Nesse sentido, a maior parte desses comentários não foi suficiente para modificar a situação encontrada, como exibido na Tabela a seguir:

Tabela 5 - Quantidade de comentários de discordância que mantiveram ou modificaram a situação encontrada no Achado 4

	Manter situação encontrada	Modificar situação encontrada
A organização não adota práticas suficientes para estabelecer e manter um processo de configuração segura	4	0
A organização não aplica adequadamente o bloqueio automático de sessão nos ativos corporativos	4	2
A organização não implementa e gerencia adequadamente firewalls nos servidores e dispositivos de usuário final	2	2
A organização não gerencia seus ativos e softwares de maneira segura	3	4
A organização não trata adequadamente as contas padrão dos ativos e softwares	0	1

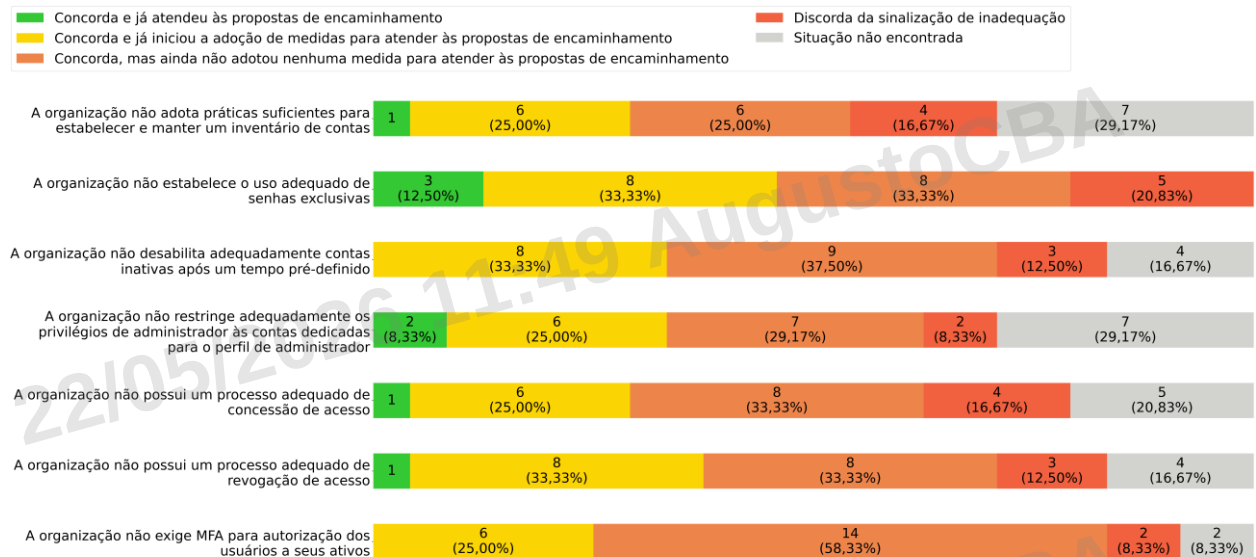
(Fonte: elaboração própria)

5.5. Achado 5 – Medidas básicas de segurança cibernética insuficientes na gestão de contas e do controle de acesso

Como pode ser observado na Figura a seguir, em 23 (16,5%), do total de 139 comentários para as sete situações encontradas, houve discordâncias. Também se

verifica que 60 (43,1%) desses comentários declaram a ausência de medidas para atender às propostas de encaminhamento.

Figura 22 - Comentários do gestor sobre as situações encontradas para o Achado 5



(Fonte: elaboração própria)

Além disso, os comentários que discordaram da situação encontrada tiveram suas justificativas analisadas. Nesse sentido, a maior parte desses comentários não foi suficiente para modificar a situação encontrada, como exibido na Tabela a seguir:

Tabela 6 - Quantidade de comentários de discordância que mantiveram ou modificaram a situação encontrada no Achado 5

	Manter situação encontrada	Modificar situação encontrada
A organização não adota práticas suficientes para estabelecer e manter um inventário de contas	3	1
A organização não estabelece o uso adequado de senhas exclusivas	4	1
A organização não desabilita adequadamente contas inativas após um tempo pré-definido	0	3
A organização não restringe adequadamente os privilégios de administrador às contas dedicadas para o perfil de administrador	2	0
A organização não possui um processo adequado de concessão de acesso	0	4
A organização não possui um processo adequado de revogação de acesso	2	1
A organização não exige MFA para autorização dos usuários a seus ativos	1	1

(Fonte: elaboração própria)

6. CONSIDERAÇÕES FINAIS

A presente fiscalização verificou a adoção de controles e medidas de segurança alinhadas às boas práticas de segurança da informação pelos órgãos e entidades da Administração Pública do Estado do Rio de Janeiro, considerando como referência as Normas Técnicas ABNT NBR ISO/IEC 27001:2022, ISO/IEC 27002:2022 e as medidas básicas de segurança cibernética dos Controles 1 a 6 dos Controles CIS versão 8.

A adoção dessas medidas permite o cumprimento de normativos estaduais, como a Instrução Normativa PRODERJ/PRE nº 02/2022, aplicável às organizações do Executivo Estadual, e organizacionais, como a Resolução TJ/OE nº 28/2022, aplicável ao Judiciário Estadual.

E de forma geral, quando adotadas, ajudam a assegurar a proteção das informações custodiadas pelas organizações auditadas, conforme disposto no art. 6º, incisos II e III, da Lei de Acesso à Informação (LAI) e a adoção de medidas técnicas e administrativas necessárias à proteção dos dados pessoais, em acordo aos artigos 46 e 47 da Lei Geral de Proteção de Dados Pessoais (LGPD).

Em linhas gerais, a fiscalização aponta um cenário incipiente de maturidade das organizações às medidas básicas de segurança cibernética, no qual 24 dos 36 jurisdicionados (66,7%) se encontram nos níveis de maturidade Inexpressivo ou Inicial.

Destacaram-se o Controle 02 de gestão de inventário de *softwares* e o Controle 03 de proteção de dados como os controles que ensejam mais atenção por parte das organizações estaduais auditadas.

Para alcançar mais efetividade à fiscalização e acelerar o processo de adequação normativa, a Equipe, exercendo seu papel orientativo, desenvolveu relatórios individualizados aos jurisdicionados, com encaminhamentos específicos às suas situações.

Nesse sentido, foram propostas até 27 medidas por auditado a serem adotadas para melhorias na segurança da informação das organizações.

Dessa forma, contata-se o caráter indutor e orientador da auditoria corrente que, em conjunto com as determinações e recomendações comunicadas, ensejará uma melhora na higiene cibernética das organizações fiscalizadas.

7. PROPOSTA DE ENCAMINHAMENTO

CONSIDERANDO o pleno atendimento ao objetivo proposto pela auditoria, qual seja, o de verificar a adoção de controles e sua aderência às boas práticas de segurança da informação;

CONSIDERANDO que o foco do presente trabalho é induzir os jurisdicionados a uma maior adoção de medidas de higiene cibernética;

CONSIDERANDO que a higiene cibernética não se esgota nos controles abordados nessa auditoria, e que deve ser encarada como um processo de melhoria contínua, norteado por um sistema de segurança da informação centrado na gestão de riscos e no uso de boas práticas consolidadas;

CONSIDERANDO o caráter orientador e dialógico do presente trabalho, assim como o alinhamento à diretriz de incremento de eficiência e efetividade na gestão administrativa;

CONSIDERANDO as informações sensíveis à segurança de informação dos jurisdicionados presentes nos autos do processo;

CONSIDERANDO que os resultados decorrentes das ações previstas no Plano de Ação poderão ser objeto de avaliação futura por meio de Monitoramento, considerando os preceitos definidos na Resolução TCE-RJ nº 302/17;

CONSIDERANDO que a metodologia empregada neste trabalho não abordou as causas específicas dos problemas identificados e que as recomendações focam na implementação de medidas estabelecidas pelos controles CIS e pelas normas ABNT, conforme observado durante o processo de auditoria.

Sugere-se ao Egrégio Plenário desta Corte de Contas a adoção das seguintes propostas:

1. **MANUTENÇÃO DO CARÁTER SIGILOSO** do presente processo, classificando-o como informação reservada, nos termos do inciso I, § 3º, art. 8º c/c incisos IV, V, VIII do art. 9º da Resolução TCE-RJ nº 433/2023, pelo caráter sensível das análises e informações que constam no relatório e seus anexos;
2. **DISPONIBILIZAÇÃO** de acesso às organizações auditadas somente a este Relatório de Auditoria Governamental e aos seus respectivos anexos individuais, excluindo o acesso aos demais anexos, visando divulgar a informação apenas a

aqueles que tenham legitimidade para conhecê-la, nos termos do § 1º, do art. 17, da Resolução TCE-RJ nº 433/2023;

3. **CLASSIFICAR COMO INFORMAÇÃO PÚBLICA** os anexos do presente processo - Matriz de Planejamento (AN02), Questionário iSegCiberBase e metodologia (AN03) e Relatório Público (AN07) - nos termos do art. 4º c/c § 1º, do art. 8º, da Resolução TCE-RJ nº 433/2023, para conferir informação ao público geral sobre a natureza da fiscalização empreendida;
4. **COMUNICAÇÃO COM DETERMINAÇÃO aos órgãos fiscalizados nesta auditoria**, nos termos do artigo 15, inciso I, do Regimento Interno deste Tribunal, para que estruturem, no prazo máximo de 60 (sessenta) dias a contar da ciência da decisão plenária, um processo administrativo no Sistema Eletrônico de Informações (SEI) com um plano de ação contendo as medidas necessárias para que cumpram as **DETERMINAÇÕES** e considerem a adoção das **RECOMENDAÇÕES** dispostas nos seus respectivos **RELATÓRIOS INDIVIDUAIS anexos**, alertando-os de que o não atendimento injustificado os sujeita às sanções previstas no art. 63 da Lei Complementar Estadual n.º 63/1990, sendo desnecessário o encaminhamento de comprovação ou esclarecimentos nos autos deste processo, já que a verificação quanto ao atendimento poderá ser realizada em auditoria futura desta Corte de Contas.

Plano de Ação				
Determinação / Recomendação	O que fazer	Como fazer	Quem vai fazer	Quando fazer

5. **COMUNICAÇÃO às Unidades de Controle Interno dos órgãos jurisdicionados desta fiscalização**, nos termos do artigo 15, inciso I, do Regimento Interno deste Tribunal, para que tomem CIÊNCIA do inteiro teor do presente Relatório de Auditoria Governamental, bem como do respectivo Relatório Individual de seu órgão (AN08 a AN43), e acompanhem a elaboração e execução do plano de ação desenvolvido a fim de assegurar seu efetivo cumprimento;
6. **ARQUIVAMENTO** do presente processo.



CAD-TI, 18/12/2024

AUGUSTO CÉSAR BENVENUTO DE ALMEIDA
Analista de Controle Externo
Matrícula 02/004823

JOÃO PAULO DE FREITAS RAMIREZ
Analista de Controle Externo
Matrícula 02/004820

Senhor Coordenador-Geral

O presente relatório foi objeto de supervisão conforme as disposições da Portaria SGE nº 05/2019 e material armazenado nos assentamentos internos desta Coordenadoria, estando, portanto, **APROVADO** por esta supervisão e encaminhado à sua apreciação para adoção das medidas cabíveis.

CAD-TI, 18/12/2024

BRUNO MATTOS SOUZA DE SOUZA MELO
Supervisor
Matrícula 02/004258

Sra. Subsecretária-Adjunta da SUB-CIDADANIA,

Após revisão, nos termos do Manual de Auditoria Governamental do TCE-RJ, aprovado pela Resolução nº 373, de 16/06/21, manifestamo-nos **DE ACORDO**.

CAD-TI, 18/12/2024

ALBERTO DE FONTES TAVARES NETO
Coordenador-Geral
Matrícula 02/004260

DE ACORDO.

Ao **GAP/NDP**, em prosseguimento.

Assinado Digitalmente por: ANA MARIA
FURBINO BRETAS BARROS
Data: 2024.12.18 21:44:24 -03:00
Local: TCE-RJ
SUB-CIDADANIA, 18/12/2024

Assinado Digitalmente por: ALBERTO DE
FONTES TAVARES NETO
Data: 2024.12.18 01:51:49 -03:00
Local: TCE-RJ
Subsecretária-Adjunta
Matrícula 02/004253

Assinado Digitalmente por: JOAO PAULO
DE FREITAS RAMIREZ
Data: 2024.12.18 01:36:26 -03:00
Local: TCE-RJ

Assinado Digitalmente por: BRUNO MATTOS
SOUZA DE SOUZA MELO
Data: 2024.12.18 01:30:49 -03:00
Razão: Processo 105895-5/2024
Local: TCE-RJ

Assinado Digitalmente por: AUGUSTO
CESAR BENVENUTO DE ALMEIDA
Data: 2024.12.18 01:15:32 -03:00
Local: TCE-RJ